Chapter 3

Risk Response and Reporting

Overview
- Domain 3 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Study
- Self-assessment Questions
- Chapter 3 Answer Key

Part A: Risk Response
- 3.1 Risk Response Options
- 3.2 Risk and Control Ownership
- 3.3 Vendor/Supply Chain Risk Management
- 3.4 Issues, Finding, and Exception Management

Part B: Control Design and Implementation
- 3.5 Control Frameworks, Types, and Standards
- 3.6 Control Design, Selection, Implementation, and Analysis
- 3.7 Control Testing Methodologies

Part C: Risk Monitoring and Reporting
- 3.8 Risk Action Plans
- 3.9 Data Collection, Aggregation, Analysis, and Validation
- 3.10 Risk and Control Metrics
- 3.11 Risk and Control Monitoring Techniques
- 3.12 Risk and Control Reporting Techniques
- 3.13 Monitoring and Reporting of Emerging Risk

Case Study
Chapter 3 Answer Key

Overview

By identifying and analyzing risk, enterprises become aware of what forces within and beyond their control might threaten their operations and how the effects of internal and external factors might manifest as impacts to production. However, documenting the results of this analysis in a risk register only provides awareness of the situation as it exists. From there, the next steps are for the enterprise to decide how to respond to the analyzed risk, which may include the design and implementation of new controls or enhancements to existing controls, and then to devise and conduct effective monitoring and reporting of risk to keep management informed in a timely manner.

This chapter represents 32% (approximately 48 questions) of the exam.

Domain 3 Exam Content Outline

A. Risk Response

1. Risk Response Options
2. Risk and Control Ownership
3. Vendor/Supply Chain Risk Management
4. Issue, Finding and Exception Management

B. Control Design and Implementation

1. Control Frameworks, Types, and Standards
2. Control Design, Selection, Implementation, and Analysis
3. Control Testing Methodologies

C. Risk Monitoring and Reporting

1. Risk Action Plans
2. Data Collection, Aggregation, Analysis, and Validation
3. Risk and Control Metrics
4. Risk and Control Monitoring Techniques
5. Risk and Control Reporting Techniques
6. Monitoring and Reporting of Emerging Risk

Learning Objectives/Task Statements

Upon the completion of this chapter, the risk practitioner will be able to:

1. Collect, review, and evaluate existing information regarding the organization's business and information system environments.
2. Identify potential or realized impacts of information system risk to the organization's business objectives and operations.
3. Identify threats and vulnerabilities to the organization's people, processes, and technologies.
4. Evaluate threats, vulnerabilities, and risk to create information system risk scenarios.
5. Establish accountability by assigning and validating appropriate levels of risk and control ownership.
6. Maintain or establish the information system risk register and incorporate it into the enterprisewide risk profile.
7. Assist key stakeholders in the selection of risk appetite and tolerance thresholds and the impact on business objectives.
8. Promote a risk-aware culture by contributing to the development and implementation of security/risk awareness and training.
9. Conduct a risk assessment by analyzing information system risk scenarios and events to generate a risk score/rating.
10. Identify the current state of existing controls and evaluate their effectiveness for information system risk treatment.
11. Determine if risk exceeds appetite and tolerance thresholds to recommend treatment options and rectify concerns.
12. Review the results of risk and/or control analysis to assess any gaps between current and desired states of the risk environment.
13. Collaborate with risk owners on the development of risk treatment plans.
14. Collaborate with control owners on the selection, design, implementation, and maintenance of controls.
15. Validate that risk responses have been executed according to risk action plans.
16. Define, implement, and refine key risk indicators (KRIs).

17. Collaborate with control owners on the identification and refinement of key performance indicators (KPIs) and key control indicators (KCIs).
18. Monitor and analyze key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs).
19. Review the results of control assessments to determine the adequacy, effectiveness, and maturity of the control environment.
20. Conduct aggregation, analysis, and validation of risk and control data.
21. Report relevant risk and control information to applicable stakeholders to facilitate risk-based decision-making.
22. Evaluate emerging technologies and changes to the environment for threats, vulnerabilities, and opportunities.
23. Evaluate alignment of business practices with risk management frameworks, standards, and regulations.
24. Facilitate tabletop exercises to verify and identify gaps in risk scenarios, capabilities, and responses.

Suggested Resources for Further Study

Institute of Operational Risk, *Operational Risk Sound Practice Guide: Key Risk Indicators*, USA, 2010

ISACA, *Risk IT Framework, 2nd Edition*, USA, 2020

ISACA, *Risk IT Practitioner Guide, 2nd Edition*, USA, 2020

Muckin, M.; Fitch, S.C.; *A Threat-driven Approach to Cyber Security*, Lockheed Martin, USA, 2019

National Institute of Standards and Technology (NIST), *Cybersecurity Framework Version 2.0*, USA, 2024, https://www.nist.gov/cyberframework

RiskLogix, "The Shortcuts Trap—Key Indicators Under Fire," 15 July 2019, https://risklogix-solutions.com/blog/key-indicators-under-fire

Self-assessment Questions

The questions in this section provide an understanding of the type and structure of questions that typically appear on the exam. Each question has a stem (question) and four options (answer choices). Many times, a question will require the candidate to choose the **MOST** likely or **BEST** answer among the options provided.

1. Which of the following choices **BEST** assists a risk practitioner in measuring the existing level of development of risk management processes against their desired state?

   A. A capability maturity model

   B. Risk management audit reports

   C. A balanced scorecard

   D. Enterprise security architecture

2. When a risk cannot be sufficiently mitigated through manual or automatic controls, which of the following options will **BEST** protect the enterprise from the potential financial impact of the risk?

   A. Insuring against the risk

   B. Updating the IT risk register

   C. Improving staff training in the risk area

D. Outsourcing the related business process to a third party

3. When responding to an identified risk event, the **MOST** important stakeholders involved in reviewing risk response options to an IT risk are the:

   A. information security managers.

   B. internal auditors.

   C. incident response team members.

   D. business managers.

4. Which of the following choices should be considered **FIRST** when designing information system controls?

   A. The organizational strategic plan

   B. The existing IT environment

   C. The present IT budget

   D. The IT strategic plan

5. Which of the following choices is the **BEST** measure of the operational effectiveness of risk management process capabilities?

   A. Key performance indicators (KPIs)

   B. Key risk indicators (KRIs)

   C. Base practices

   D. Metric thresholds

Chapter 3 Answer Key

Self-assessment Questions

1. **A. A capability maturity model grades processes on a scale of 0 to 5, based on their maturity. It is commonly used by enterprises to measure their existing state and then to determine the desired one.**

   B. Risk management audit reports offer a limited view of the current state of risk management.

   C. A balanced scorecard enables management to measure the implementation of strategy and assists in its translation into action.

   D. Enterprise security architecture explains the security architecture of an entity in terms of business strategy, objectives, relationships, risk, constraints, and enablers and provides a business-driven and business-focused view of security architecture.

2. **A. An insurance policy can compensate the enterprise monetarily for the impact of the risk by transferring the risk to the insurance company.**

   B. Updating the risk register (with lower values for impact and probability) does not actually change the risk, only management's perception of it.

   C. Staff capacity to detect or mitigate the risk may potentially reduce the financial impact, but insurance allows for the risk to be completely mitigated.

   D. Outsourcing the process containing the risk does not necessarily remove or change the risk.

3. A. Business managers are accountable for managing the associated risk and determining what actions to take based on the information provided by others, which may include collaboration with and support from information security managers.
   B. Risk response is not a function of internal audit.
   C. The incident response team must ensure open communication to management and stakeholders to ensure that business managers/leaders understand the associated risk and are provided enough information to make informed risk-based decisions.
   D. Business managers are accountable for managing the associated risk and will determine what actions to take based on the information provided by others.
4. **A. Review of the enterprise's strategic plan is the first step in designing effective IS controls that fit the enterprise's long-term plans.**
   B. Review of the existing IT environment, although useful and necessary, is not the first task that needs to be undertaken.
   C. The present IT budget is one of the components of the strategic plan.
   D. The IT strategic plan exists to support the enterprise's strategic plan.
5. **A. Key performance indicators (KPIs) are assessment indicators that support judgment regarding the performance of a specific process.**
   B. Key risk indicators (KRIs) only provide insights into potential risk that may exist or be realized within a concept or capability that they monitor, not necessarily at the process level.
   C. Base practices are activities that, when consistently performed, contribute to achieving a specific process purpose. However, base practices need to be complemented by work products to provide reliable evidence about the performance of a specific process.
   D. Metric thresholds are decision or action points that are enacted when a KPI or KRI reports a specific value or set of values.

Part A: Risk Response

The risk response phase of risk management, shown in **figure 3.1**, focuses on the decisions made regarding the correct way to address identified risk. Risk response is based on the information provided in the earlier steps of risk identification and risk assessment. The desire to reduce risk is balanced with the constraints placed on the enterprise through budget, time, resources, strategic plans, regulations, customer expectations, and other business and industry factors. Management should be prepared to justify to stakeholders why its risk response decisions reflect the best balance of these competing factors. Additionally, an effective risk response process provides a roadmap to implementing agreed-upon changes and/or controls according to a reasonable schedule.

Figure 3.1—The IT Risk Management Life Cycle

Risk response should be undertaken in a way that protects current operations to the greatest extent possible. In some cases, response activities may cause disruption. However, the goal should be to respond to risk without unduly impairing operations. Actions and controls intended to address risk should be chosen with this goal in mind.

3.1 Risk Response Options

Key Takeaways

- The enterprise exists to pursue its business goals as set by management, and risk response exists to facilitate that objective.
- Absent any competitive advantage or other business benefit, an acceptable risk should be accepted.
- The decision to mitigate or transfer risk is generally a matter of which costs less.
- Risk is avoided when other options are more costly than the value that the enterprise stands to gain.

The goal of risk response is to bring risk into alignment with the organizational risk appetite and tolerance (see section 1.10 Risk Appetite, Tolerance, and Capacity for more information). Factors such as staff expertise, strategic direction, legal and regulatory requirements, and organizational culture should be acknowledged when considering precisely what responses are best suited to each area of risk.

3.1.1 Aligning Risk Response With Business Objectives

The risk assessment report and risk register document the risk noted during the identification and assessment phases of the risk management process. Both the report and the register should indicate the assessed level or priority of each risk. Risk practitioners should keep in mind that these recommendations are guidelines and that several recommendations may be provided. Management is responsible for evaluating and responding to the recommendations included in the report, first by determining the best response and then developing an action plan and implementation strategy that addresses the risk in a manner consistent with the risk appetite and tolerance of the enterprise.

The enterprise exists to meet its mission in the manner deemed best by management. Accordingly, the decisions made around all aspects of risk management may diverge from recommendations made by risk practitioners. The role of the risk practitioner is not to decide on behalf of the organization. Instead, the risk practitioner's role is to ensure that management has the best available information to make informed decisions. Management should be kept aware of the drivers for risk management, such as compliance with regulations and the need to support and align the risk response with business priorities and objectives. This does not preclude a risk response that would negatively impact the ability of the organization to meet its mission, but it does mean that such a response would need to be considered very carefully.

3.1.2 Risk Response Options

Evaluation of an appropriate risk response is part of the risk management life cycle, not a one-time activity. There are four commonly accepted options for risk response:

- Risk acceptance
- Risk mitigation
- Risk sharing/transfer
- Risk avoidance

The purpose of defining a risk response is to bring risk in line with the enterprise's defined risk appetite and tolerance as cost-effectively as possible, not to eliminate or minimize the risk at all costs. All response activities incur some cost, typically a mix of the direct cost of response and the potential cost of impact. Finding the right balance is a management function that considers all the constraints mentioned earlier, such as budget, time, and resources.

Risk Acceptance

The choice to accept risk is a conscious decision made by senior management. Risk acceptance means recognizing both the existence of risk and its potential impact, then deciding with full awareness to allow (assume) the risk to remain without (further) action. Management is always accountable for the impact of a risk event should it occur, so the decision to accept a risk is made according to the organizational risk appetite and risk tolerance.

In some industries, risk acceptance may be more easily recognized by the term "self-insurance." Under a self-insurance model, an enterprise sets aside or has access to sufficient resources to absorb the cost of impact should a risk event occur and takes no further action. Self-insurance and risk acceptance are synonymous in practice.

Because the goal of risk management is to bring risk within acceptable levels as cost-effectively as possible, risk that falls within the organizational risk appetite without any action being taken generally should be accepted. Such risk is acceptable by definition, and risk acceptance tends to be the most cost-effective treatment option. Exceptions to this approach may arise under unusual circumstances, such as cases where an action that would reduce an already acceptable risk would also result in increased business opportunity; however, such cases are rare.

Management may also choose to accept a risk *outside* of the risk appetite, but within the range of the organization's risk tolerance. Risk tolerance is typically a factor when either there is no technically feasible remedy to the risk available or the cost of possible actions outweigh their benefits, yet management wants to continue the activity associated with the risk. See section 1.10 Risk Appetite, Tolerance, and Capacity for more information.

Examples of risk acceptance as a result of risk tolerance include:

- Projections indicate that a certain project will not deliver the required business functionality by the planned delivery date, but management decides to proceed with the project hoping that the delivery will come soon after the planned date.
- A particular risk would have catastrophic consequences but is assessed to be extremely rare, and approaches to reduce it are cost prohibitive.

Risk must be formally accepted by someone empowered to act on behalf of the enterprise at a level commensurate with the projected consequences associated with the risk. Risk acceptance done informally or at the wrong level represents a form of risk ignorance, which refers to both the failure to identify or acknowledge risk or the blind acceptance of risk without fully understanding or acknowledging the actual risk level.

Too often, acceptance of risk is based on poorly calculated risk levels. Many enterprises have found, in the wake of an incident, that the actual level of risk accepted was far greater than what they had intended to accept. Careful review of actuarial data or the outcomes of similar incidents at other enterprises and their resulting impact may help the risk practitioner estimate true likely incident costs. Framing risk acceptance in terms of self-insurance may help risk practitioners explain the true implications of accepting risk to management.

In addition to accepting risk at the outset (which relates to inherent risk), enterprises should also recognize that other approaches to risk management typically yield residual risk that must be acceptable to the organization. A mitigated risk, for instance, is typically still nonzero and must be evaluated to ensure that it falls within the organizational risk appetite.

Additionally, risk acceptance is not a one-time process. The level of risk and potential impact of an incident can change dramatically as assets increase or decrease in value, new threats emerge, attackers gain additional skills or motivation, vulnerabilities are discovered, the existing controls become weaker, or the operations team becomes less diligent. Enterprises should conduct regular reviews of their accepted risk to ensure that these continue to be consistent with senior management's levels of risk appetite and risk tolerance. Wherever a risk owner is unwilling to accept the current risk, a new risk response is necessary. This process is continued through iterations until the risk reaches an acceptable level, at which point the risk owner should formally accept the risk. Acceptance of residual risk should also include accountable ownership of the controls that produce the appropriate mitigation to ensure that these are suitably maintained and remain effective after acceptance.

Risk Mitigation

Risk mitigation refers to actions that the enterprise takes to reduce a risk. Some examples of risk mitigation are:

- Strengthening overall risk management practices, such as implementing or maturing internal processes
- Installing a new access control system
- Improving organizational policies or operational procedures
- Developing effective plans for incident response, disaster recovery, or business continuity
- Using compensating controls to address areas of persistent weakness in production systems

Mitigation is typically achieved through the implementation of controls, which affect the frequency and/or impact of the risk. See Part C: Risk Monitoring and Reporting for more information.

Realistic choices for risk mitigation may be determined (in part) by the scope of the risk or the speed at which an incident can expand. In some cases, multiple controls may be needed to reduce risk to an acceptable level. Risk practitioners should take care to account for the cost of controls relative to their effects on risk. Controls whose implementation cost exceeds the risk that they are meant to mitigate are cost-ineffective and should not be deployed without further justification.

The goal of mitigation is to reduce risk to an acceptable level, not to eliminate risk entirely. Once mitigation is complete, acceptance of residual risk should be documented and subject to periodic reevaluation in the same manner as the acceptance of inherent risk.

Risk Transfer/Sharing

Risk acceptance can be a form of self-insurance. This differs from risk transfer, which is the decision to reduce loss by having another enterprise incur the cost. The most common example of risk transfer is purchasing third-party insurance, which provides a guarantee of compensation or replacement should a loss occur. Partnerships and outsourcing agreements are also forms of risk transfer. In these situations, two or more organizations work together under an arrangement in which the parties share in the potential profit and loss as per agreed-upon terms. Typically, these agreements include monetary indemnity in the cases of loss or failures, similar to insurance payments, although the legal and practical terms are somewhat different.

The term “risk transfer” is misleading, because an enterprise that sustains a substantial loss may accrue costs beyond what can be reimbursed by insurance, particularly in the form of damage to its brand (reputational risk). For instance, a major financial institution that exposes large amounts of confidential customer data might be reimbursed for immediate expenses by an insurance policy. However, customers lose trust in the brand and may take their business elsewhere. These long-term impacts are typically not covered by any form of risk transfer, because reputational sentiment lies with the primary organization, not with insurers or business partners or vendors. Enterprises should remember that stakeholders rarely regard the transfer of risk as complete absolution of blame.

Transferred risk, like all other risk, should be reviewed on a regular basis to ensure that it remains appropriate and adequate. For example, an enterprise should ensure that the current amount of insurance is adequate to cover losses and that the enterprise is compliant with the terms and conditions of the coverage. Outsourcing arrangements should include regular reviews of security compliance reports or operational procedures to ensure that the outsourced services are conducted according to contractual agreements. Risk transfer is only effective when agreements are properly maintained, and the moment after an incident occurs is the worst time to realize that a contract recently expired, a premium was unpaid, or the third-party vendor has not maintained agreed-upon business practices.

Risk Avoidance

In each of the three prior response options, the goal is to create an acceptable level of risk under which to continue operations. In limited circumstances, it may be impractical or technically impossible to bring the risk of an activity into line with the risk appetite and risk tolerance. Under such circumstances, the best choice may be to exit the activities or conditions that give rise to that risk, or risk avoidance.

Risk avoidance is the choice that remains when no other response is adequate, meaning the following are true:

- The current exposure level is deemed unacceptable by management.
- Mitigation or transfer that would bring the risk in line with acceptable levels is either impossible or would cost more than the benefits that the enterprise derives from the activities.

Some examples of risk avoidance include:

- Relocating a data center away from a region with significant natural hazards

- Evacuating staff from a work area in which there is substantial civil unrest or threat of war
- Declining a project where the business case shows a substantial likelihood of failure
- Rejecting a partnership agreement in which potential losses are allocated to the enterprise, but the partner stands to benefit from most potential profits
- Deciding not to use proprietary technology or software from a vendor because it has only recently begun operations or faces uncertain future prospects

Consideration should also be given to the "costs" of risk avoidance. This cost can be measured in the loss of a business opportunity or other opportunities lost because of the decision to avoid the risk.

The actual decision to avoid risk is made by senior management. The role of the risk practitioner is to make the case for why avoidance may be the correct choice given the circumstances. For this reason, all other options should be considered and rejected before recommending risk avoidance, allowing the risk practitioner to explain in detail what else has been considered and why transfer and mitigation are unacceptable options.

3.1.3 Choosing a Risk Response

In some cases, the decision to pursue a particular risk response may not be immediately apparent. Mitigation and transfer may both be feasible options, or a risk may be acceptable but also have the potential for mitigation in a way that would improve operational efficiency. In such cases, the best risk response is typically determined based on analysis.

Management may consider several factors when choosing a risk response, including:

- Priority of the risk as indicated in the risk assessment report
- Complexity of recommended controls in cases involving mitigation
- Alternatives that are suggested through further analysis
- Cost of the various response options, including:
  - Acquisition cost
  - Training cost
  - Impact of productivity
  - Maintenance and licensing costs
- Management decision based on:
  - Financial objectives
  - Tolerance and variability of loss
  - Relative importance
  - Risk tolerance and risk appetite
- Requirements for compliance with regulations or legislation
- Alignment of the response option with organizational strategy
- Possibility of integrating the response with other initiatives
- Organizational culture (see section 1.3 Organizational Culture and Ethics for more information)
- Time, resources and budget available for the response
- Environmental and market conditions and evolution
  - Historical progress and transformation of the associated risk

The selection of the appropriate response is often based primarily on the value obtained for the cost. Where more than one risk response option would yield acceptable risk, does the cost of implementing a specific risk response provide enough value to the enterprise for it to be a wise decision? This is inherently a management decision. However, risk practitioners are often involved in framing the situation and answering questions.

Specific responses to risk are typically recommended in business cases, which document the problems and one or more potential solutions as well as providing detailed analyses on which management may base decisions. Beyond being common and useful tools for decision support, business cases also serve as

operational tools against which to evaluate and support investments throughout their life cycles. The risk practitioner may find it helpful to use analysis methods to evaluate options. For instance, one might conduct a cost-benefit analysis for each alternative to estimate its likely value to the organization relative to the immediate expense. Another option would be to calculate return on investment (ROI), which illustrates how much time would pass before the enterprise would recoup the cost through savings or increased revenue.

Risk responses should be documented in the risk register with clear accountability and time frames for completion. Many risk responses cannot be implemented instantly, and a plan of action and milestones (POA&M) can be useful as a means of identifying a basis for tracking progress and setting review times up to the point of completion. Risk practitioners should ensure that these reviews are completed and that planned mitigations are not superseded or abandoned to competing priorities.

3.2 Risk and Control Ownership

Key Takeaways

- Every risk should be formally owned by a relevant senior manager.
- Risk owners also own the controls that apply to their risk but typically delegate management of those controls.
- Controls are deployed to bring risk to acceptable levels and should not be more costly than the risk they are meant to control.

Every risk identified in the risk register should be owned by a manager empowered to make decisions on behalf of the enterprise. In general, the risk owner should be a senior executive or manager responsible for one or more of the business processes or functions that may be impacted. The risk practitioner should communicate with risk owners to ensure that they are aware of what risk responses have already been implemented and responses that are pending implementation.

Current and anticipated levels of risk should be clearly conveyed in ways that provide insight into the aggregate risk presented to the organization as a whole. Multiple instances of low risk can aggregate to become moderate or even severe; for instance, many businesses that relied on global suppliers prior to 2020 considered the risk associated with any single supplier to be acceptable, but when the pandemic interrupted transportation of goods on a massive scale, some of those organizations struggled to maintain operations. Aggregate risk is evaluated against the strategic risk appetite and deals with organization-wide impacts. Where aggregation is incomplete or ineffective, senior executives may lack the information they need to make good business decisions to manage challenging circumstances. At its worst, the implications of poor aggregation can reach the level where an organization's continued existence may be in jeopardy.

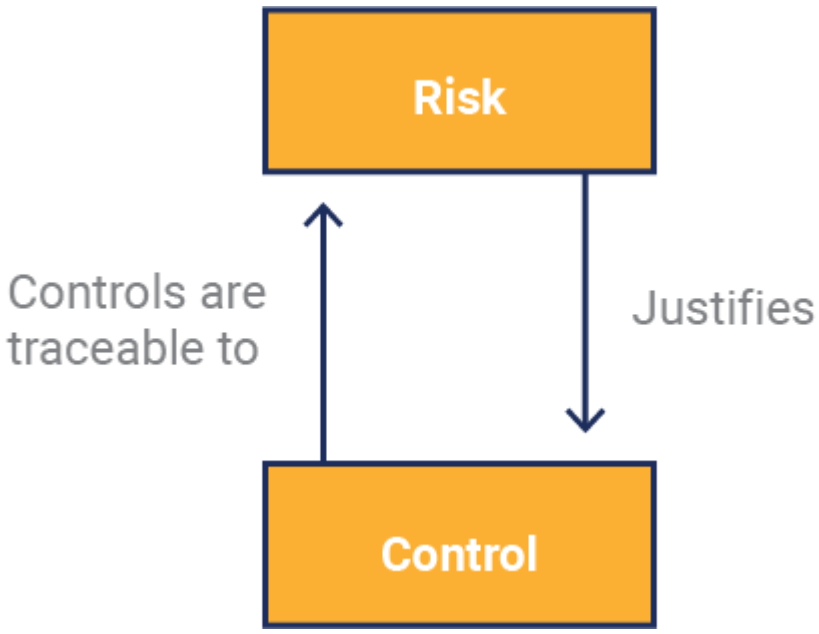
3.2.1 Ownership and Accountability

The purpose of determining risk ownership is to ensure accountability. Risk owners need to actively drive the activities performed by risk practitioners to ensure the desired outcomes can be clearly understood. A risk owner must be someone with the budget, authority, and mandate to select an appropriate risk response based on analyses and guidance provided by the risk practitioner. If someone who lacks one or more of these is chosen as the risk owner, that person will be incapable of exercising the full scope of ownership responsibilities, and true accountability cannot be expected. Similarly, every risk should have a single risk owner. Where more than one senior leader may be impacted by a risk, seek consensus among those affected for which is the best suited to take ownership given resources, focus, expertise, and other factors. Similarly, a control generally should be owned by the owner of the risk that it mitigates. However, the control may be owned by someone else in the case of controls that affect more than one risk. Risk and control owners should be recorded in the risk register.

Accountability extends beyond the basic risk response decision to approving specific controls when mitigation is the chosen risk response. Types of controls are examined in more detail in section 3.5 Control Frameworks, Types, and Standards. However, the concept is to create a direct link between risk and control, so that all risk is addressed through appropriate controls and all controls are justified by the risk that mandates their existence. This relationship is shown in **figure 3.2**.

A detailed knowledge of controls may not be reasonable for all risk owners, and significant technical expertise is typically not necessary at the owner level. The risk owner generally owns any controls associated with that risk and is accountable for ensuring that their effectiveness is monitored. In some areas where there are regulations or laws that apply to risk, the risk owner may have to prepare (or direct preparation of) standard reports on the status of risk, any incidents that may have occurred, and the level of risk currently faced by the enterprise from one or more functional areas, which can then be included in aggregate risk reporting across the enterprise.

Figure 3.2—Risk in Relation to Control



3.3 Vendor/Supply Chain Risk Management

Key Takeaways

- Outsourcing is a form of risk transfer but can also create risk.
- Relying on outside parties for vital functions may result in an inability to operate.
- Services and products provided by outside parties may not perform as expected and can even include built-in threats or vulnerabilities.
- Key suppliers should be rigorously evaluated before being deemed trustworthy.

Not all risk arises from within an enterprise. Outsourcing is a form of risk transfer, but reliance on a vendor also creates exposure. The risk practitioner should take care to address risk that arises when an organization outsources business functions, supportive services, IT services, and data management. Typically, ownership of data and business processes remains with the outsourcing enterprise, not the contracted service provider. This relationship can create legal liability that may be difficult for the outsourcing enterprise to manage, because outsourcing by its very nature places most of the day-to-day operations, staff, and procedures within the scope of the contract outside of the enterprise's direct control.

In an evolving technology landscape, such as with AI solutions, the supply chain and vendor relationship extends beyond the traditional third-party. **Figure 3.3** describes vendor relationships.

Figure 3.3—Supply Chain Parties

Party	Characteristics	Example
First Party	The consumers of a solution/product	The enterprise Customers
Third Party	The entities a provider directly contracts or collaborates with. (e.g., data providers, model developers, or cloud service providers)	AWS Google OpenAI Hugging Face Snowflake
Fourth Party	Vendors or subcontractors that a third-party vendor relies on, the “vendors of vendors”	Cloudflare TSMC Dell Microsoft
Fifth Party	Vendors that fourth-party vendors rely on, continuing the chain of outsourcing	ASML Holdings Equinix SAP Microsoft Oracle
N^{th} Parties	Vendors beyond the third party within a given relationship “ecosystem” depending on how many levels of dependencies exist (i.e., 4th, 5th, 6th, 7th, etc.)	Power utilities Environmental services Data center facilities management

Source: Adapted from ISACA, *ISACA® AAISM™ Official Review Manual*, USA, 2025

Outsourcing does not terminate the ownership or liability of a risk owner for data or performance; for instance, the enterprise remains accountable for the security of information that it stores with a third-party host. The move toward centralized cloud-computing data centers for hosted storage can also create challenges for organizations obligated by law or contract to retain their data within particular jurisdictions. The more accurately the regulatory obligations of an outsourcing enterprise are understood and conveyed, the more likely it is that third-party providers will be able to align their practices with those requirements. Even so, the organization remains accountable for the use of its data by any third party. When data management is outsourced, the outsourcing enterprise is responsible for ensuring that adequate security requirements and regulations for handling the information have been written into the outsourcing agreement. It is also critical that mechanisms exist to ensure that these requirements and regulations are being followed. Depending on the particular circumstances, an outsourcing organization may require the right to audit the processes of the outsourced supplier or to obtain an attestation from external auditors or independent reviewers. Standards of due care and/or due diligence may be warranted in certain situations or regulated industries.

Concerns that should be considered in relation to the risk of using an outsourced supplier include:

- Hiring and training practices of the supplier
- Reporting and liaison between the outsourcing enterprise and supplier
- Time to notify and respond to any incidents
- Liability for noncompliance with terms of the contract
- Nondisclosure of data or business practices
- Responding to requests from law enforcement
- Length of contract and terms for dissolution/termination of contract
- Location of data storage including backup data
- Separation between data and management of data belonging to competing firms
- Existence and regular testing of resiliency plans (e.g., business continuity and disaster recovery)
- Handling of data after termination of contract (e.g., return, destroy, transfer, etc.)

The relationship between an outsourcing provider and the enterprise is defined by a contract. Legal requirements written into contracts should also address the jurisdiction for any complaints or disagreements with the provider and regulations in the host country regarding disclosure to law enforcement and data transmission, as well as storage across borders. The risk practitioner may not have direct involvement in negotiation of these terms but should verify whether security and regulatory requirements are addressed in agreements with suppliers and service providers.

When an enterprise is contracted to provide or deliver services or equipment, the risk of noncompliance with the agreement must be met through review, monitoring, and enforcement of the contract terms. Any failure to meet contract terms must be identified and addressed as quickly as possible. Typically, ownership of data and business processes remains with the outsourcing organization, not the contracted service provider. This relationship can create legal liability that may be difficult for the outsourcing organization to manage, because outsourcing by its very nature places most of the day-to-day operations, staff, and procedures within the scope of the contract outside the enterprise's direct control. Enterprises with influence over terms may want to ensure that third-party providers are obligated to provide them with notice of breaches that do occur and summary reports of remediation efforts, at least for incidents that meet specified severity criteria.

Limited mitigation may be attained through carefully worded indemnity clauses that require the vendor to repay the losses suffered due to legal or regulatory violations on the part of the service provider. Contractual terms are commonly enforceable through service level agreements (SLAs). An SLA is a formal guarantee that certain performance targets or standards will be met and includes predetermined compensation for failure to meet those targets. In many cases, compensation takes the form of monetary offsets against future expense. Risk practitioners should recognize that even generously crafted SLA remedies are a form of risk sharing and do not offset reputational or long-term impacts.

Where enterprises rely on third parties to carry out key aspects of their business functions, the need for third-party assurance takes on a different connotation. If a third party is going to perform work for the enterprise, nondisclosure agreements (NDAs) form the foundation needed to protect the intellectual property of the enterprise from being disclosed to unauthorized personnel. This is especially relevant when a penetration test or other assessment has been performed to ensure that any uncovered vulnerabilities could not be exploited to attack the enterprise. Outsourcing services are also subject to disasters, even when they include high redundancy with data replicated across continents.

The risk practitioner should take steps to ensure any provider of outsourced services used by the enterprise is compliant with the organization's defined requirements or at a minimum generally accepted good practices, whether through external audits such as Statement on Standards for Attestation Engagements Number 18 (SSAE 18) or US Health Information Technology for Economic and Clinical Health (HITECH) reports, or having the right to conduct an audit on behalf of the organization. Where possible, reviewing an outsourcing provider's security policies and procedures may provide an additional level of assurance. This can be difficult to arrange unless it is written into the original agreement, so the risk practitioner should be aware and involved in all discussions regarding the establishment of third-party agreements to ensure that executives make decisions with a clear understanding of the associated risk.

The risk practitioner should understand the variety of cloud computing models and capabilities that the organization may desire to pursue. These can include common offerings such as software as a service (SaaS), infrastructure as a service (IaaS), and platform as a service (PaaS), as well as various forms of cloud application development such as containers and dockers. Different jurisdictions where data is stored or processed may introduce an unacceptable level of risk in the forms of litigation or incident response efforts. Accordingly, the risk practitioner needs to be aware of where data has the potential to be stored, accessed, and processed.

Despite the risk associated with third-party activities, many enterprises find benefits in outsourcing and contracting with other organizations to offer specialized services. This can allow the organization to focus on its core business and strategy without distraction.

One evolving area of interest as it relates to third parties is their use of AI-enabled tools. Organizations of all sizes are adopting AI as a means of quickly parsing and processing irregular data. However, AI systems "learn" by ingesting excessive volumes of data and carrying forward the lessons learned from processing them. There may be risk associated with a vendor or third-party provider using the organization's data to train its AI models. Organizations that leverage AI through third parties may also incur obligations under law and regulation. The risk practitioner should determine whether and how AI functionality is leveraged by a particular vendor or service provider and account for associated risk as part of third-party risk management reviews.

3.4 Issues, Finding, and Exception Management

Key Takeaways

- Changes to hardware, configurations, or software should be carefully controlled.
- Emergency changes bypass the schedule, not the testing process.
- Every change must be tested before it is deployed to production, because untested changes may directly introduce problems.

Variation from the norm or desired outcome represents uncertainty and is a source of risk. Enterprises can manage this risk by applying strong procedures to areas of variation, including formal approaches to configuration, release, exception, and change management. Despite these controls, issues and findings may arise, warranting special handling.

3.4.1 Configuration Management

Technical complexity and the use of leading-edge technology can be key causes of information risk that scale with the size of an enterprise. This is especially true when working with tools that leverage various forms of artificial intelligence (AI). Standardizing system configurations can greatly reduce this complexity by simplifying planning, testing, implementation, and maintenance activities. The risk practitioner should first determine whether standard configurations have been established and approved and then verify their proper documentation. Effort should also be made to spot-validate that documentation is used when planning changes or rollouts of new software and updated to reflect these changes upon their implementation.

3.4.2 Release Management

Even in environments where software is developed for internal use, it is very important to formally manage the release of new updates or versions of developed applications. Releases should be coordinated with production staff, independently verified by nondevelopers, protected prior to deployment, and aligned with the enterprise's overall life cycle for system development (see Chapter 4 Technology and Security for more information).

3.4.3 Exception Management

Policies and procedures exist to standardize decisions and behavior. However, enterprises may encounter circumstances where its usual practices are unsuitable due to timely, technical, or administrative constraints. Any exception should be formally documented and approved by a senior manager or executive before it is acted upon. Exceptions are not necessarily problems; however, every exception represents a deviation from standards and introduces complexity, which can create or obscure risk. Therefore, exceptions should be granted sparingly and reviewed at least annually to ensure that they are still necessary, with any unnecessary exceptions removed.

3.4.4 Change Management

Requests to change systems or configurations should be subject to formal review and approval by a dedicated committee. Change tends to alter the risk profile of an enterprise, so effective risk management calls for change advisory boards (CABs) comprised of representatives from several organizational departments who are responsible for overseeing all IS operations and approving changes to those systems. Having a CAB with a sufficiently broad perspective provides a communication channel between the business units and the IT department, which helps to ensure that changes are proposed and considered in ways that cater to both technical requirements and operational efficiency.

Under an effective change control model, changes are submitted for review by the CAB, which verifies that:

- The change request does not unknowingly affect risk or security.
- The change is formally requested, clearly justified, approved, and documented.
- The change is scheduled at a time convenient for the enterprise and IT.
- All stakeholders affected by the change are advised of the change.
- The change request includes test, implementation, and rollback plans.
- The change will not compromise the enterprise's security baselines.

The intention of this model is to provide a balance between allowing needed changes to occur and preserving system reliability and stability. CABs typically have procedures for "emergency" requests, but this should only take the form of changing the timing of when requests are considered. Allowing changes to be made to the production environment without proper CAB review may expose the enterprise to unidentified risk, including risk that may exceed acceptable levels.

The change management process interacts with and oversees all of the other processes previously described in this section. Updates to configurations, software releases, and exceptions should all be processed as changes and be subjected to review by the CAB.

3.4.5 Issue and Finding Management

Internally identified issues and findings that arise from third-party assessments or audits demonstrate a need to take corrective action. However, before action can be taken, the issue or finding must be fully understood and prioritized relative to resources and other constraints. From there, the enterprise needs to determine what situation or outcome would constitute an acceptable end state and develop a response to create that end state. In most cases, responses will involve changes, which should go through the change management process previously discussed. Addressed issues and findings should then be monitored to ensure that the timely actions produced the anticipated results and identify any new issues that may arise as a result of the changes made.

The response to a risk event may also be driven by context-specific considerations. For instance, data breaches involving patient data in the healthcare industry are often subject to breach-reporting laws, and financial services organizations may be expected to report “material” cybersecurity incidents to regulators. These reporting requirements typically have specified timelines from the date of discovery, and response processes should be developed and exercised in a manner that ensures ability to meet applicable timelines.

Clear action plans should be defined to resolve the identified issue or finding. Action plans should also specify the date by which the issue will be resolved. Management should formally accept the risk until the issue has been resolved and apply compensating controls to mitigate the risk. If the identified issue cannot be resolved by the specified date, management should be promptly informed, and risk should be accepted after deliberation by the management.

Part B: Control Design and Implementation

Mitigation is the most common response to risk. The risk practitioner should be aware of both the current control environment and any anticipated changes. Controls are implemented to reduce or maintain risk at acceptable levels; however, controls may be poorly maintained, unsuitable for the risk that they are meant to control, or incorrectly configured, and such controls may not adequately control risk. Controls should be regularly reviewed to determine and ensure their effectiveness.

In addition to evaluating the effectiveness of each control for its intended purpose, the risk practitioner should verify the correct balance between technical, administrative (managerial), and physical controls. Implementation of a technical control, such as a firewall, requires training for the staff member who manages or operates it, correct procedures for its configuration, assignment of responsibilities for its monitoring, and schedules for regular testing. If these coinciding administrative controls are not in place, the technical control may be less effective, giving stakeholders a false sense of security that results in unidentified vulnerabilities, which is an ineffective use of resources and a greater risk than anticipated or intended.

3.5 Control Frameworks, Types, and Standards

Key Takeaways

- Controls reduce risk by affecting threat, vulnerability, and impact; different types of controls affect these in different ways.
- Frameworks specify what should be accomplished, while standards also specify how it must be done.
- Administrative controls rely on and benefit from human judgment.
- Technical controls are governed by their programming.

- Physical controls safeguard both people and technology.

Controls are generally categorized as belonging to one of five categories, described in **figure 3.4**.

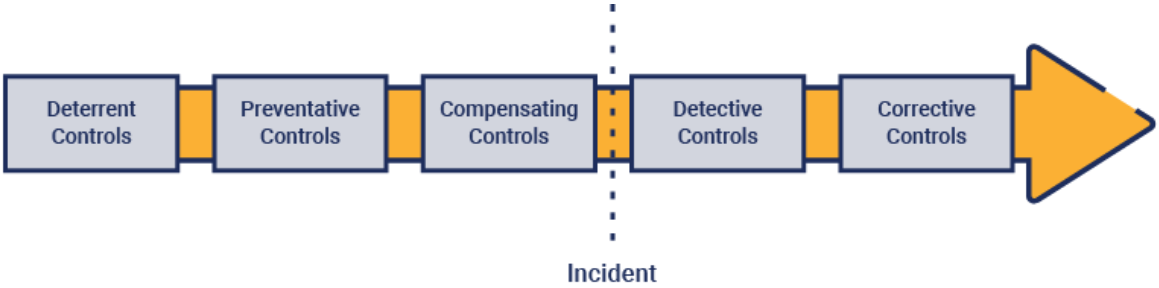
Figure 3.4—Control Categories

Category	Description
Preventive	Inhibit or impede attempts to violate security policy and practices. Encryption, user authentication and vault-construction doors are examples of preventive controls.
Deterrent	Provide guidance or warnings that may dissuade intentional or unintentional attempts at compromise. Warning banners on login screens, acceptable use policies, security cameras, and rewards for the arrest of hackers are examples of deterrent controls.
Detective	Provide warning of violations or attempted violations of security policy and practices without inhibiting or impeding these actions. Audit trails, intrusion detection systems (IDSs), and checksums are examples of detective controls.
Corrective	Remediate errors, omissions, unauthorized uses, and intrusions when detected. Data backups, error correction, and automated failover are examples of corrective controls.
Compensating	Offsets a deficiency or weakness in the control structure of the enterprise, often because the baseline controls cannot meet a stated requirement due to legitimate technical or business constraints. Placing unsecured systems on isolated network segments with strong perimeter security and adding third-party challenge-response mechanisms to devices that do not support individual login accounts are examples of compensating controls that, while not addressing the direct vulnerabilities, make it harder to exploit them.

The interaction between the control types is shown in **figure 3.5**. The time of control effects relative to an incident is shown in **figure 3.6**.

Figure 3.5—Control Category Interdependencies

Figure 3.6—Time of Control Effects Relative to an Incident



Assessing the control environment provides the risk practitioner with an opportunity to evaluate both the risk culture of an enterprise and the effectiveness of its risk management program, which can be used to determine both the level of risk currently facing the organization and the seriousness of that risk. In general, risk is more serious when any of the following are true:

- Controls are inadequate or nonexistent.
- The wrong controls are being used.
- Controls are regularly ignored or bypassed.
- Controls are poorly maintained.
- Logs or control data is not reviewed or monitored.
- Controls are not tested on a regular basis or using standardized procedures.
- Changes to the configuration of controls are not managed.
- Controls can be physically accessed and altered by arbitrary individuals, without approval.
- Duties are inadequately segregated (see Chapter 4 Technology and Security for more information)

3.5.1 Control Standards and Frameworks

Selection of controls requires evaluation and implementation. Based on data collected through appropriate analysis methods (e.g., cost-benefit analysis, ROI), management decides on the best available control or group of controls to mitigate a specific risk. A poorly implemented control may end up posing a risk to the enterprise if it creates a false sense of security or causes other controls to function less effectively. In particular, the implementation of technical controls requires proper procedures and training, and all controls should be assigned to specific owners accountable for ensuring that they are monitored and tested on a regular basis.

Adoption of standards and frameworks facilitates the process of selecting controls by specifying what should be done and, in the case of standards, also directing how to do it. Standards are written with the intent that adopting organizations will certify formal compliance. The 27000-series of standards from the International Organization for Standardization (ISO) focuses on information security, with ISO/IEC 27002:2022 dealing specifically with security controls. Many industries also have standards for security within their respective sectors. For instance, the Payment Card Industry Data Security Standard (PCI DSS) is used by all organizations that process debit or credit cards. Similar standards are found in the healthcare, accounting, audit, and telecommunications industries. Standards may be supplemented or even superseded by law or regulations in some locations.

In some cases, organizations may choose to adopt standards without intending to formally certify compliance. Standards may also include or be supported by frameworks, which provide sets of fundamental controls whose adoption is recommended, but whose implementation is left up to the organization. The US National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) adopts a threat-centric approach and breaks down recommended cybersecurity practices into core components, rigor-influenced implementation tiers, and organization-specific profiles. Even within the United States, CSF is voluntary guidance; however, organizations around the world use it as a source for leading practices when developing their cybersecurity programs. Similarly, the Cloud Security Alliance (CSA) has built a control framework tailored to the operational and security requirements of cloud computing.

Whether voluntary or mandatory, standards, frameworks, and regulations all influence the control environments of the organizations that adhere to them. See Chapter 1 Governance for more information.

3.5.2 Administrative, Technical, and Physical Controls

Controls can be further categorized as administrative (managerial), technical, or physical, as shown in **figure 3.7**.

Figure 3.7—Control Methods

Category	Description
Administrative (managerial)	Related to the oversight, reporting, and operations of a process. Typically, performed by people rather than automated, these include controls such as policy and procedures, training and awareness, configuration/change management, employee development, and compliance activities. Administrative controls tend to be subject to considerable human judgment.
Technical	Provided through the use of digital technology, equipment, or devices. Sometimes called “logical” controls, technical controls include firewalls, network or host-based intrusion detection systems, passwords, and antivirus software, and they generally safeguard networks, computer systems, and data. Technical controls need administrative controls to operate correctly and can generally be compromised by someone who gains physical access to their sources of activity.
Physical	Based on restriction of physical access to something, which may be a particular device, room, or facility. Physical controls include locks, fences, armored conduit, security guards, and other factors that interact with the physical world and monitoring capabilities that are physically directed (such as closed-circuit television cameras). Physical controls require maintenance, monitoring, and the ability to assess and react to an alert should a problem be identified.

3.5.3 Capability Maturity Models

The risk practitioner may find it useful to compare the state of the enterprise’s risk management program to an established model of capability maturity that contains the essential elements of effective processes for one or more disciplines. A capability maturity model (CMM) describes an evolutionary improvement path from immature (*ad hoc*) processes to disciplined, mature processes with improved quality and effectiveness. With the aid of a maturity model, enterprises can gain a clear understanding of their current working practices and the areas that require improvement, which in turn makes it possible to set realistic long-term goals for risk management.

A mature enterprise that has defined, reliable processes that it follows consistently and continuously seeks to improve is much more likely to prevent incidents, detect incidents sooner, and recover from incidents more rapidly. Enterprises should seek to implement well-structured risk management procedures across all departments and regions and ensure that every business process, system, and software development project follows core risk management principles, policies, procedures, and standards.

Key elements that may be used to measure the maturity of IT risk management capability include:

- Support of senior management
- Regular communication between stakeholders
- Existence of policies, procedures, and standards
- Availability of a current business impact analysis
- Logging and monitoring of system activity

- Frequency of log reviews
- Risk assessments and reviews done on a scheduled basis
- Periodic testing of business continuity and disaster recovery plans
- Staff training on topics relevant to IT risk
- Involvement of risk principles and personnel in IT projects
- Gathering feedback from users and stakeholders
- Validating organizational risk appetite and risk tolerance levels
- The amount of time taken to detect/resolve a security incident
- Selection and adoption of risk mitigation strategies
- Standardized measures for assessing risk and defining risk ratios
- Exception management
- Risk and control ownership

Improvements in both the efficiencies and effectiveness of the risk management capability require the consistent application of policies and procedures. If these procedures are followed consistently, then the efficiency and effectiveness of the risk management practices will generally improve. The levels defined by a CMM are typically attained on the basis of self-assessment, although certain CMMs do provide a means for third-party assessment and validation. For more information on CMMs, see section 4.1.1 Maturity Models.

3.6 Control Design, Selection, Implementation, and Analysis

Key Takeaways

- Risk may change over time, so controls that work as designed may eventually fail to effectively control risk.
- When controls need to be updated or replaced, careful planning is important.
- Changes to controls may be implemented as sudden changeovers or deployed in parallel, which is more costly but affords greater fallback protection.
- After implementation, document any lessons learned and assess the effectiveness of the new control.

When designing controls, the first step is to be aware of the current state of the control environment. The risk practitioner determines the current state of IT risk using the results of control testing activities and incident management programs. A current-state assessment therefore refers to the condition of the program at a point in time and should be regarded as accurate only at the time the risk state is measured. However, when the assessment accurately reflects the current state, regular reviews may be used to determine the state over a defined time frame.

Current risk levels are essential because they provide the reference point to understand the gap between the current and desired state. Risk practitioners should seek to determine the reason for this gap and identify workable solutions that may address the disparity.

Some tools that can be used to determine the current state of IT risk include:

- Audits
- CMMs
- Control tests conducted by the control owner or custodian
- Incident reports
- IT operations and management evaluation
- Enterprise architecture assessment
- Logs and automated monitoring
- Media reports of new and emerging vulnerabilities and threats

- Direct observation and self-assessments
- Third-party assurance
- User feedback
- Vendor reports
- Vulnerability assessments and penetration tests

Although an audit report tends to provide the most comprehensive view of the current state of controls, risk practitioners should take care in requesting audits. Auditors rely on evidence and the use of published, rigorous methodology, which leaves little room to argue with findings. Some managers and risk owners see this as negative appraisals of their ability. Where use of auditors is permitted, their assistance can be invaluable. An alternative to requesting an audit is to obtain a copy of a recent audit report and use it as the starting point for self-assessments to identify any changes in the environment.

3.6.1 Control Design and Selection

Once the specific shortcomings of existing controls and configurations are understood, the next step is to design or select controls or enhancements to close the gap between the current state and an acceptable level of risk. Controls may attempt to prevent an incident (proactive) or facilitate the detection, containment, and recovery of operations should an incident occur (reactive). Because these are different roles, proactive controls are sometimes called safeguards, while reactive controls are often called countermeasures. For example, a sign that warns a person about a risk of fire is a safeguard against a fire starting, while a fire extinguisher or sprinkler system is a countermeasure that puts a fire out should one start.

Every enterprise has controls. In general, an effective control is one that works as intended, meaning it prevents, detects or contains an incident, or enables recovery from a risk event. However, the purpose of a control is specifically to maintain risk at an acceptable level. A control might function as intended yet not effectively manage risk, especially as the enterprise and its business processes change over time. As a result, it is common for an enterprise to have some situations where the controls currently in place are not sufficient to adequately protect the enterprise. In most cases, this requires the adjustment of the current controls or the implementation of new controls within the system, referring to deterrent, preventative, detective, or corrective controls.

In some cases, it may not be feasible to reduce the risk within the system to an acceptable level by either adjusting or implementing controls due to reasons such as cost, job requirements, or availability of controls. For instance, a small enterprise that has only a single individual with administrator rights generally cannot implement proper separation of duties (SoD). Industrial systems, sometimes called operational technology (OT), are also often incapable of supporting additional controls due to custom integration and nonstandard protocols and architectures. In such cases, the risk owner may choose to implement compensating controls to reduce the risk. Compensating controls address weaknesses through concepts such as layered defense, increased supervision, or increased audits and logging of system activity. Effective compensating controls are not duplicative or redundant and avoid increasing the existing risk surface of the asset being protected. These measures combine with existing controls to offset the risk that could not be addressed directly.

Controls are typically selected from capabilities either already present within the environment or available commercially. However, controls may be designed specifically for environments based on need. Where design is the intent, the risk practitioner should consider not only functionality but also maintenance and sustainability. Whether controls will be automated or manual, fail safe (open), or secure (closed), or provide inputs to other controls or processes are all factors that should be considered. Designers should also understand throughput or speed requirements of associated or affected processes to ensure that any delay or impediment to regular processing remains within tolerable levels. These same considerations apply when analyzing existing controls within operational systems.

3.6.2 Control Implementation

Selected controls should be tested in a separate environment before implementation. To the extent practical, this test environment should mimic the production environment, including instances of existing controls in their current states. In prior years, establishing such test environments tended to be extremely costly. Today, with virtualization and container technology, it may be relatively trivial to establish a testing environment, even as a temporary arrangement, to evaluate specific capabilities.

Accurately simulating the production environment is useful because successful testing of new or enhanced controls in as realistic a context as possible greatly improves the odds of a successful changeover in production. The changeover process should be coordinated through formal change management, with any system outages communicated to all likely stakeholders across the organization. Where possible, the risk practitioner should deconflict change implementation with critical business functions in order to reduce impacts if an outage goes longer than expected or the changeover is not successful. In general, this deconfliction occurs within the CAB.

Implementation and testing should not be limited to technical controls. Administrative and physical controls require comparable levels of coordination, rigor, and evaluation before being fully implemented and relied upon to deliver intended outcomes. Additionally, technical controls affecting access permissions to networks, systems, or data are frequently implemented according to SoD determinations made on an administrative basis. Wherever possible, changes in policy or procedure should be promulgated in draft format and assessed for operational impact across a diverse subset of the affected users before becoming mandatory.

Changeover (Go-live) Techniques

After final tests have been conducted and change management has been coordinated, implementation begins as scheduled. There are three common changeover methods used to transition from one system, technology, application, or version to another:

- Parallel
- Phased
- Abrupt

Even with rigorous testing, the production environment may not respond to changes in the manner expected. For this reason, changeover planning should always include a fallback (rollback) scenario. These concepts are discussed below in detail and apply equally to basic controls within complex systems and changes made at the system level.

Parallel Changeover

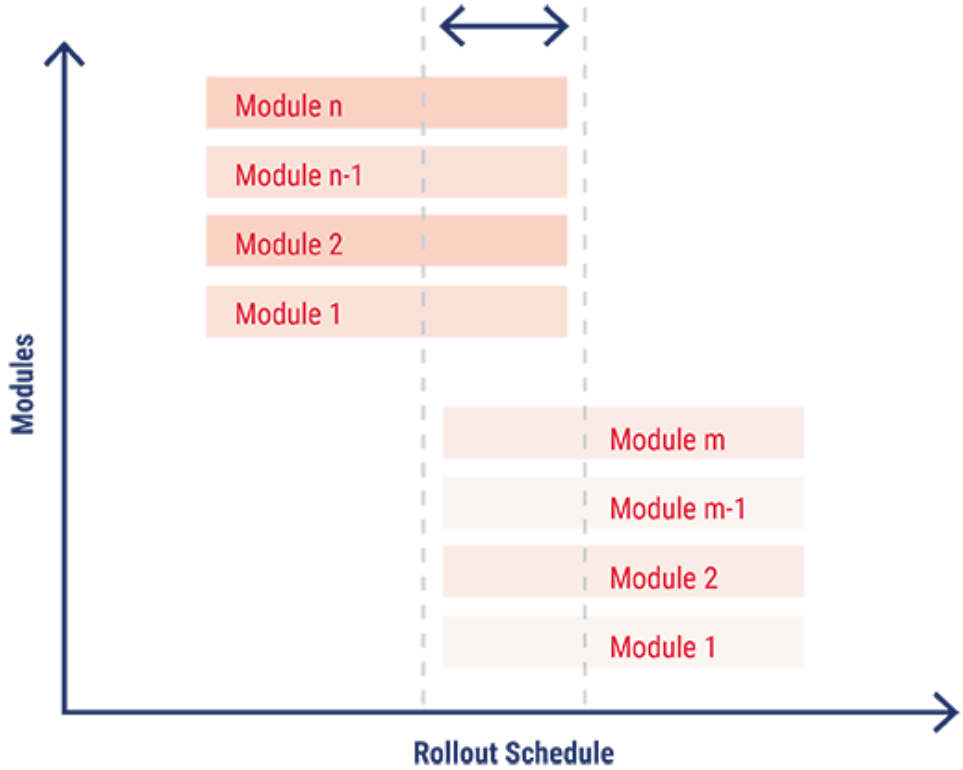
A parallel changeover means operating both the new system and the old system simultaneously. Parallel processing allows the project team greater latitude to test the reliability and performance of the new system and ensure that it is working correctly before removing the old system from service, which minimizes the risk of a failed changeover to the new systems and allows staff to train on and become familiar with the new system before it is in full production.

Parallel changeover provides the safest and quickest means of changeover in case the changes need to be rolled back. Since the current system is fully operational, the new system can be stopped at any point where results are not as intended.

Disadvantages of a parallel changeover include the cost of maintaining and monitoring both systems at the same time and ensuring data consistency between these systems while both are operational.

Figure 3.8 shows the principles of a parallel changeover.

Figure 3.8—Parallel Changeover



Source: ISACA, *CISA Official Review Manual, 28th Edition*, USA, 2024

While virtualization reduces the hardware burden of this arrangement, parallel processing is true duplication of effort and typically doubles licensing costs relative to normal operations. In some environments, it may be possible to operate in partial-parallel by limiting duplication to key functions. As a general rule, the cost of parallel processing is justified where there is significant complexity that may lead to an extended outage *and* the cost of that outage exceeds the cost of operating in parallel. For instance, when adopting a new enterprisewide authentication system, maintaining an ability to authenticate under the old system for a period of time may be justified, because authentication affects all functions, and failure could constitute a self-imposed denial of service (DoS) against the entire enterprise. In contrast, if the control has a limited scope, a parallel approach may be too costly.

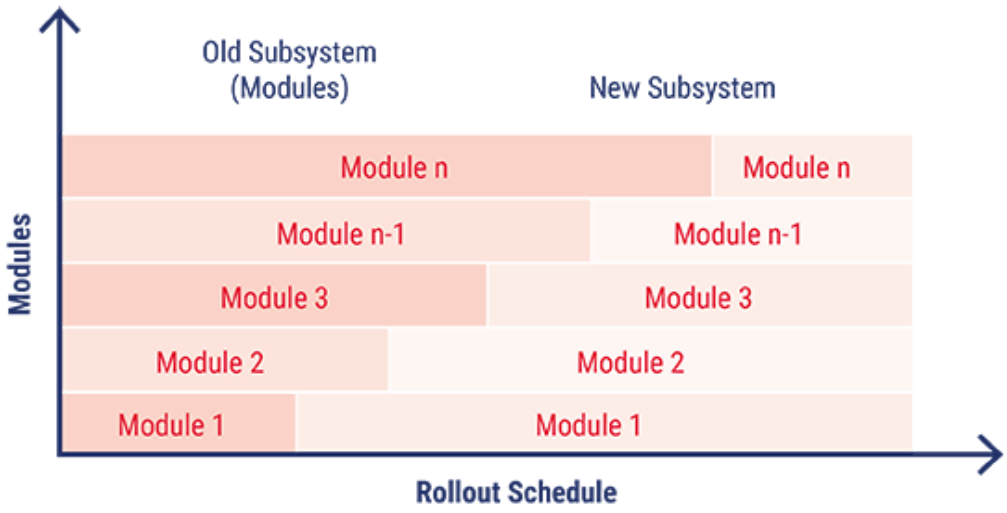
Phased Changeover

A phased changeover is conducted by replacing individual components or modules of the old system with new or modified components. This reduces the risk by gradually rolling out the new modules in ways intended to avoid impacting the entire system. Depending on the type of system, this type of changeover is not always possible. Some risk factors that may exist in a phased changeover include:

- Resource challenges arising from having to maintain unique environments with distinct hardware or software
- Operational challenges arising from having to maintain and monitor two different sets of user guides and procedures and potential confusion over changes in terminology
- Challenges maintaining consistency of data
- Extension of the project life cycle to cover delays that may arise from incremental changes not going as planned
- Change management for requirements and customization at each phase such as quantity, frequency, and SLA or operational level agreement requirements

Figure 3.9 shows the principles of a phased changeover.

Figure 3.9—Phased Changeover



Source: ISACA, *CISA Official Review Manual, 28th Edition*, USA, 2024

Some systems that appear to be candidates for phased changeover may present unexpected problems. Testing phased implementations is difficult, because the test environment may not accurately represent the state of production as it moves further from the starting point. Modules that are expected to deliver the same outputs may differ in ways that are sufficient to have downstream effects, resulting in impacts to data integrity or system performance. For instance, a logging system that stores timestamps in a different format may create errors in automatic parsing software or create false-positive responses in intrusion prevention systems that have established heuristic baselines.

When implementing changes using a phased approach, consider building in considerable leeway at each phase to take full account of how the project is progressing. This is especially valuable in complex systems, where the effects of a change may not be known until the full production calendar has completed a cycle.

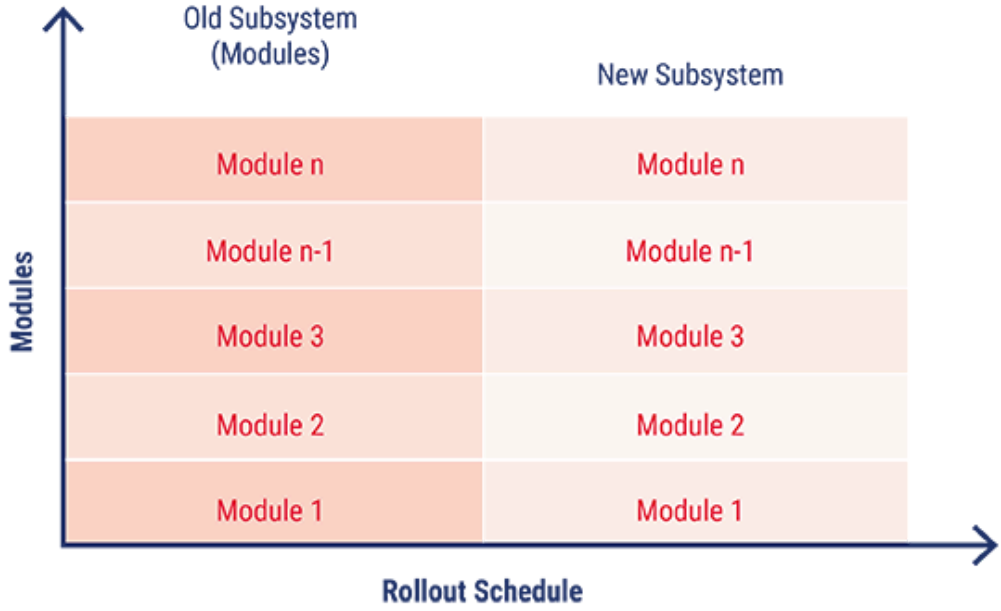
Abrupt Changeover

An abrupt changeover means a single-instant movement from the old system to the new system, with the old system immediately taken offline. Abrupt changeover is the riskiest of the changeover processes because of the potential for lost opportunities in business processing if it becomes necessary to revert to the earlier system. For this reason, abrupt changeover is most prevalent in cases in which rollback is relatively assured or the impact of lost processing is minor. Many limited-scope controls are implemented using an abrupt changeover model.

Figure 3.10 demonstrates the principles of an abrupt changeover.

Although the technical element of an abrupt changeover happens suddenly, this should not be interpreted as a lack of preparation. Updates to documentation, staff training, and communication to stakeholders should all happen in advance of the cutover. In fact, it is more important that these activities be done deliberately and in advance in an abrupt changeover than in a parallel or phased scenario. Risk practitioners coordinating abrupt changeovers should ensure that the enterprise has adequate support capabilities available to handle potential disruptions and rollbacks in a timely manner.

Figure 3.10—Abrupt Changeover



Source: ISACA, *CISA Official Review Manual, 28th Edition*, USA, 2024

Challenges Related to Data Migration

Migrating from one system or making fundamental modifications to an existing system may require the migration or conversion of data, which poses inherent risk to both data integrity and availability. The risk practitioner should assess the process used for data migration to identify any likely areas of concern. Additionally, procedures for recovery of data in its preconversion state should be developed, tested, and practiced before conversion as insurance against unexpected negative outcomes. Some considerations for data conversion are listed in **figure 3.11**.

Figure 3.11—Data Conversion Key Considerations

Consideration	Guidelines for the Risk Practitioner
Completeness of data conversion	Verify that the total number of records from the source database appears in the new database without loss (minus any intentionally removed).
Data integrity	Verify that the data is not altered manually, mechanically, or electronically by a person or program, except strictly as required by conversion. Integrity problems include transposition and transcription errors, substitution or overwriting of records, and problems transferring particular records, fields, files, libraries, and instances.
Storage and security of data under conversion	Verify that data is backed up before conversion and that controls are in place to safeguard data while in storage or transit. Unauthorized or unnecessary copies may lead to misuse, abuse, or theft of data from the system.
Data consistency	Verify that the same field/record accessed by the new application is consistent with that used by the original application for the same purpose, which ensures consistency during repeat testing.
Business continuity	Verify that the application supports added or appended records, which is important for ensuring seamless business continuity.

Fallback (Rollback)

In any change scenario, whether it involves implementing a new system or making changes to an existing system, there is always a possibility that the change will not work as anticipated. The project team should have a fallback plan so that it is possible to return to the prechange status and resume normal processing. The procedures for this reversion should be developed and approved as carefully as the change plan and subjected to rigorous testing before the changeover is attempted.

3.6.3 Postimplementation Review

Whether an implementation project succeeds or fails, a timely postimplementation review offers the best opportunity to capture lessons learned so that they can be applied to future projects.

Some questions to ask during the review include the following:

- What went well during the project, and what could have been done better?
- Did the project bring the risk within acceptable levels?
- Were all user requirements and business objectives met?
- If any inadequacies or deficiencies were identified, how might these be addressed?
- Were specified methodologies, standards, and techniques followed? If not, why not?

- How does the final cost compare to estimates?

Were the resources allocated for the project sufficient?

It is considered a good practice to hold a postimplementation review as soon as is practical after completing an implementation project. However, not all lessons associated with a given project may be immediately evident. A second, joint review by the implementation team and key stakeholders is often worthwhile after the project has been completed and changes have been in production for a sufficient period of time to assess their effectiveness and value to the enterprise. In addition to highlighting unexpected deficiencies, this second-pass review may also reveal unanticipated value.

3.6.4 Control Documentation

The risk practitioner plays a key role in ensuring that controls are properly set up, operated, maintained, and evaluated, with results reported to management on a regular basis. Formal documentation promotes consistency in task execution that manifests in reliable reports. Control management procedures include:

- Proper installation
- Creation of policies and procedures to support operations
- Implementation of change management procedures to ensure correct configuration
- Training of staff to monitor, manage, and review controls
- Assignment of responsibility for monitoring and investigation
- Creation of a schedule for review and reporting
- Measurement of initial key performance indicators (KPIs)

As risk responses are implemented, the risk practitioner should ensure that each mitigation project has been implemented according to the intent and design of the project architects and that any changes did not erode or diminish effectiveness. Each control should have its own documentation that includes justification for its implementation, accountable and responsible owners, and review and reporting schedules. Exclusions applicable to the functioning of a particular control, such as omitting certain kinds of traffic or allowing certain roles to bypass it, should also be carefully justified and documented.

3.7 Control Testing Methodologies

Key Takeaways

- Controls should be tested under the most realistic conditions practical.
- Production data should not be used for testing unless necessary and expressly approved by management.
- User acceptance testing (UAT) can help ensure that the control creates expected business value.

Controls exist to mitigate risk. When improperly implemented, the opposite may occur. Not only may a control fail to meet an enterprise's requirements, but poor implementation or functional inadequacy may actually promote a security breach. Control testing is an opportunity to uncover flaws early enough to prevent that failure and do so cost-effectively. A comprehensive testing program includes testing at as many levels as may be needed to assess the complete scope of implementation. This includes testing at unit/component, integration/system, and end user levels, good practices based on standards used at each level, and the results of all tests should be formally documented. Controls should be tested in ways that account for their full intended scope as well as any applicable exclusions.

Testing may be done on a progressive or regressive basis. Progressive testing begins with expectations and looks for flaws, while regressive testing works backward from known problems to identify causes. Both

forms of testing are commonly used throughout the testing process. The risk practitioner may find regression testing to be useful in determining whether incidents have root causes in policy or standards.

3.7.1 Good Practices for Testing

Effective testing typically considers specific considerations for data, version control, and code to the extent that these apply to particular controls. These are discussed in the following sections.

Data

The validity of testing depends, in large part, on the appropriateness of test data. Test data should be structurally complete and allow the testing of all possible process functions and error handling, which includes “fuzzing”—testing the limit of the acceptable range of values and values beyond the allowable range in order to verify the functionality of input validation and process integrity controls.

Although testing simulates production use, the behavior of a system being tested is typically not fully predictable. Using distinct test data rather than production data is preferable in order to prevent the disclosure of sensitive data to people or systems that may not be approved to view or process it. Where use of live data is necessary, sensitive data elements should be displayed in a manner that makes them unreadable, such as masking sensitive information by displaying it as special characters or altering the data itself. Production data should be used as test data only in exceptional cases upon successful deidentification and with specific management approval.

Environmental Separation

As mentioned previously, development or testing environments should be separated from production areas to prevent the potential for cross-population of data or application code outside the approval process. Depending on the enterprise, this separation may be done at the network level, may include physically separate workspaces, or may require entirely distinct teams of developers to be working on test and production systems. The risk practitioner should understand the separation model used by the organization and the rationale for managing separation in that fashion to ensure that it is consistently applied in practice. Wherever physical separation, logical separation, or both are difficult, the enterprise should implement compensating controls commensurate with the risk level.

Version Control

There is always risk that a change to a system will overwrite or bypass functionality previously implemented or changed in a system. Version control refers to the assignment of specific version numbers or tracking mechanisms for each revision of a system, making it possible to distinguish between versions. Version control tracks the current iteration of something in development, checks for previous changes when a new change is implemented, and can be used to ensure that the correct source version is staged for a move to production use. The risk practitioner should take care to ensure that reports from content reviews (including code testing) and other testing apply to the correct versions of components and systems.

Code Locking

Part of the process of moving a new or modified system or application into production is to lock down the source code in order to ensure that it cannot be inadvertently modified or intentionally tampered with after it has been approved for final testing. Some organizations call this final version gold code or locked code. In high-sensitivity environments, integrity-checking tools such as digital checksums may be used to validate that no changes have been made since approval.

Unit Testing and Code Review

Systems function through the combined effort of their components. Because complexity increases potential points of failure, it may become more difficult to pinpoint the sources of problems as components are

integrated. Testing done at the level of a particular control, module, or section of code often cannot demonstrate full operational capacity within a system. However, it may reveal certain errors in ways that can be remedied before moving to integration.

In software development environments, developers follow organizational coding standards, including proper use of comments, and these standards should reflect good practices of the industry wherever compatible with organizational goals. Additionally, all new or changed source code should be reviewed by a third party to validate quality and compliance prior to production use. The same basic standard applies to administrators making changes to configurations for routers and other network hardware. Third-party review is valuable because it can detect both unauthorized changes and implementations of error handling, input validation, or documentation that may be inadequate. The process of third-party review should be done by an impartial, knowledgeable party and should be based on standards, not personal preferences.

Self-assessments are valuable as part of the development process. However, formal testing should always be done by individuals not involved in the creation of the deliverables being tested. Where detailed engineering information is available, it may be possible to perform this testing from a vulnerability assessment perspective. Commercial software and vendor products typically do not provide sufficient insight into their fundamental operations to allow for this informed perspective, making a review a more subjective assessment based on the penetration-testing model.

Some organizations are now using AI to develop and execute automated test cases based on general parameters. Where user interfaces are available, AI tools can create their own testing based on observed user behavior and adapt those cases in scenarios where the UI changes. AI testing tools also generally operate on a code-aware basis, allowing them to recognize what areas of functionality have changed and focus testing on those areas.

It is unlikely that the risk practitioner will be expected to conduct unit testing or code reviews, but he or she should be aware of the concepts and limitations of each approach and ensure that standards are in place and are used as the basis for any testing that is performed. In addition, the risk practitioner should be aware of any organizational or departmental policies that apply to testing and ensure that procedures are designed in ways that account for and support these higher-level controls.

Integration/System Testing

After the individual components of a system have been tested, the next step in a complex system is for the entire system to be tested to assess how the components work together with their interfaces and deliver overall operational capability. Integration testing shows the interactions of the system with upstream and downstream peers, so it is distinct from component-level testing. Controls may have effects beyond their anticipated scope, so system testing should be performed whenever a new control is implemented or an existing control is altered.

Unit testing and initial integration testing are often performed in an area distinct from the environment used for final system testing. This is done to separate the developer from the final testing and acceptance process and to help ensure that the components being tested are not being modified by the developer during testing. This separation also provides a level of assurance that where system problems arise, they are integration problems and not problems with the individual components.

One purpose of system testing is to assess the security functions designed into the system and ensure that these have been built according to the design (considering any deviations that have been properly approved and documented). **Figure 3.12** describes different testing options available at the system level.

Figure 3.12—Options for System Testing

Test	Description
Recovery	Checks the system's ability to recover after a component failure
Security	Verifies that the modified/new system includes provisions for appropriate access controls and does not introduce any vulnerabilities that may compromise other systems
Stress	Determines the maximum number of concurrent users/services the application can process by increasing the number of users/services on an incremental basis
Volume	Determines the maximum volume of records (data) that the application can process by increasing the volume on an incremental basis
Stress/volume	A hybrid approach that uses large quantities of data to evaluate performance during peak hours
Performance	Compares the performance of the subject system to similar systems using well-defined benchmarks
Compliance	An approach for compliance-specific regulations or standards (such as the General Data Protection Regulation) that would prevent personally identifiable information from remaining in the test environment

User Acceptance Testing

For a project to deliver what it promises is a significant accomplishment. However, a project whose deliverables are not what the enterprise needs cannot be called successful beyond a semantic level. It is surprisingly common for the processes used to define the requirements for projects to misalign with the functional capabilities that are needed in practice. The best way to identify these areas of conflict is to allow the intended users of a system to interact with it—a process commonly called user acceptance testing (UAT).

The purpose of UAT is to verify that the system meets user requirements and expectations, not whether it meets the stated design. UAT may highlight problems with functionality, training, or process flow unanticipated by the requirements process and, therefore, undetectable by unit or integration testing. A failure in UAT suggests flaws in the enterprise's processes for needs analysis and requirements definition. For this reason, IT project management methodologies are increasingly incorporating UAT into the development process on an iterative basis, so that key functionality can be assessed early enough that changes may be considered and approved without negatively affecting the project schedule. In general, the

earlier that UAT can begin, the less costly it will be to make any changes that may be requested, and the lower the risk that the final product will fail to meet business needs.

Quality Assurance

Quality assurance (QA) is a systematic plan of all actions necessary to provide adequate confidence that an item or product conforms to established technical requirements without the need for testing. When these actions are carried out in a tightly controlled production environment, the result can be a very high degree of reliability that what was produced necessarily conforms to expected standards. Unlike quality control (QC), which looks for individual examples of flaws, a failure in QA suggests flaws in the organization's *processes*. The basic QA paradigm includes detection of such flaws and their remediation in the assurance processes to eliminate repetition of problems in future iterations.

QA addresses whether the project delivered what it promised in the stated design, not whether that design actually meets user requirements and expectations. Accordingly, even the most mature QA process cannot replace UAT. Customization outside prescribed standards also tends to work against QA, which is most effective where the target of production is an exact replica of an ideal model.

Testing for Nontechnical Controls

Administrative and physical controls should be tested with the same level of rigor applied to technical controls and may be assessed from the same progressive or regressive perspectives. Many physical security systems have known vulnerabilities that can be reduced or eliminated through effective simulation training, such as identifying blind spots in camera coverage or distorted images due to insufficient lighting.

Whenever people perform security functions, their behavior should be assessed against clear procedures on the basis of adherence to expectations and norms; however, the foremost reason for employing human security is to afford an opportunity to exercise judgment that a technical control cannot demonstrate. Because every exercise of judgment represents a deviation from expected outcomes, assessments of human security performance should be done under conditions as realistic as is practical, with sufficient frequency to establish operational norms.

In workplaces where information is central to the business, the challenges associated with security roles provided by humans extend beyond guards and cameras. Analysts, operators, and administrative staff are frequently in positions where action or inaction may create or increase risk. Policies and procedures are the means by which organizations inform human judgment to keep risk within acceptable levels. As with traditional security functions, adherence to these procedures and overarching policy should be tested under realistic conditions whenever practical. These assessments may include spot-checks of vital functions, structured walkthroughs of business processes, and statistical evaluation of incidents based on human error.

3.7.2 Updating the Risk Register

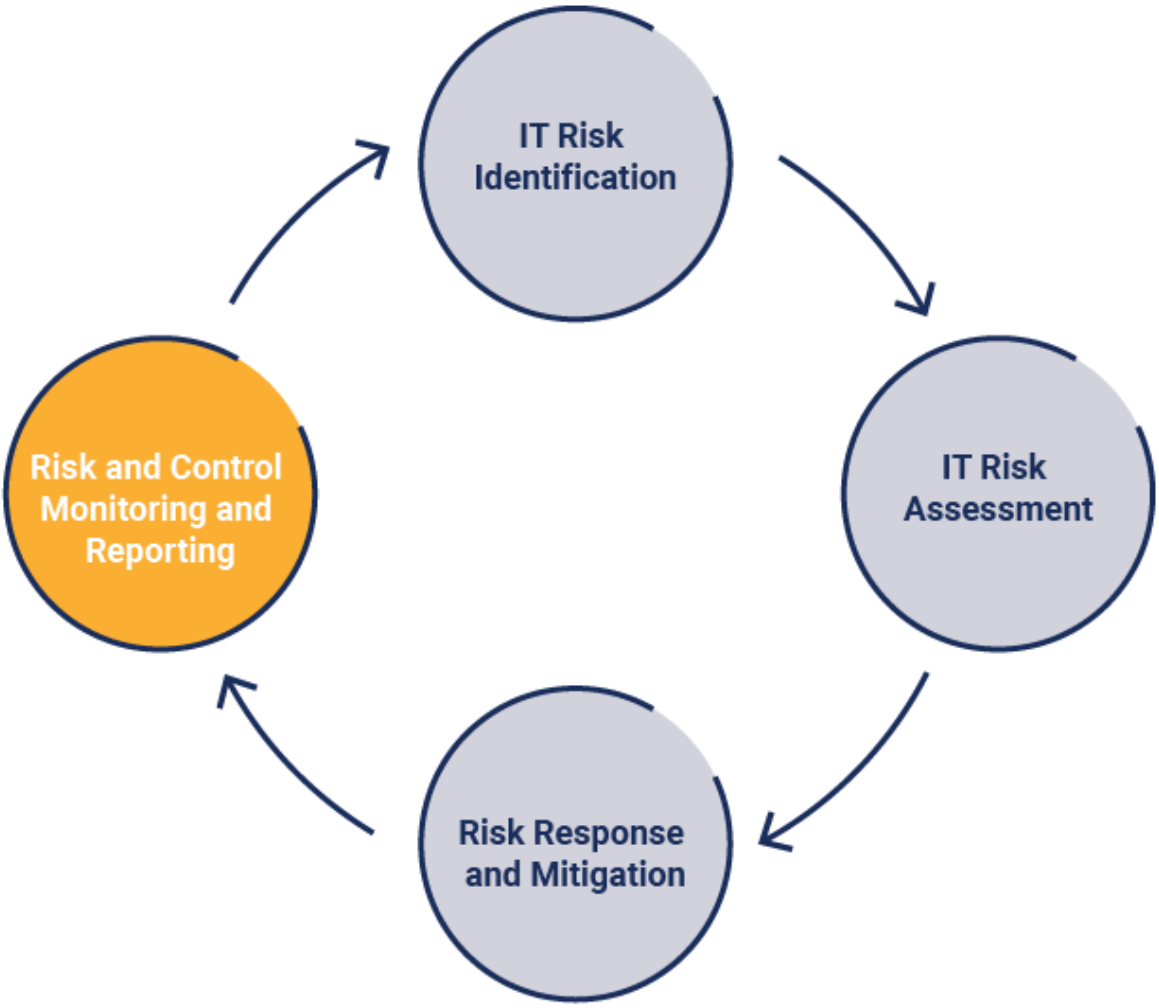
The risk register should show the progress of testing and attainment of milestones during the progress of each mitigation project. After a control has been validated as effective, residual levels of risk are formally accepted by risk owners, with the risk register updated to reflect the changes. By keeping the risk register accurate and up to date, the risk practitioner ensures that it is consistently available as a resource for risk management activities across the enterprise.

Part C: Risk Monitoring and Reporting

Enterprises rely on monitoring and reporting functions to identify risk for assessment and response. The risk practitioner can best manage risk when monitoring is broad enough to provide a reasonable view of the risk environment, but not so broad that the results are lost in a flood of data. Indicators for both performance and risk should be carefully considered and deliberately chosen based on their alignment with

organizational goals. Identification and use of key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs) can greatly improve the process of monitoring. In addition, periodic assessments and testing may be necessary as a means of identifying new and emerging risk. Risk and associated controls change over time, so continuous monitoring is a useful and important element of the risk management life cycle as seen in **figure 3.13**.

Figure 3.13—The IT Risk Management Life Cycle



The effectiveness of any monitoring program depends in large part on its successful integration with reporting. Consistent, repeatable methods of reporting provide management with a means of assessing the efficacy of the risk response and mitigation activities and justify the expenses of supporting security controls. Reports also assist management in exercising due care and diligence in protecting the organization's assets and meeting regulatory requirements.

The risk environment generally evolves with the goals and strategies of the enterprise. The risk practitioner should keep management aware of changes in risk over time and the impact of those changes to the environment. Elimination of risk is an infeasible goal. However, risk should be considered as part of strategic planning so that changes can be anticipated and mitigated to acceptable levels when new strategic plans are unveiled, designed, and implemented, rather than relying on the risk response process to address these retroactively.

3.8 Risk Action Plans

Key Takeaways

- Risk actions are planned based on risk scenarios, analysis, and response decisions made by management.
- The best choice for risk response depends on business goals.
- Project management principles should help guide the development and implementation of a risk action plan.

The risk practitioner plays a consultative role in assisting risk owners with deciding on the correct response to a risk: accept, transfer, mitigate, or avoid. The ultimate decision on what action to take lies with the risk owner, but the risk practitioner can and should provide advice on technologies, policies, procedures, and control effectiveness and how to leverage existing controls.

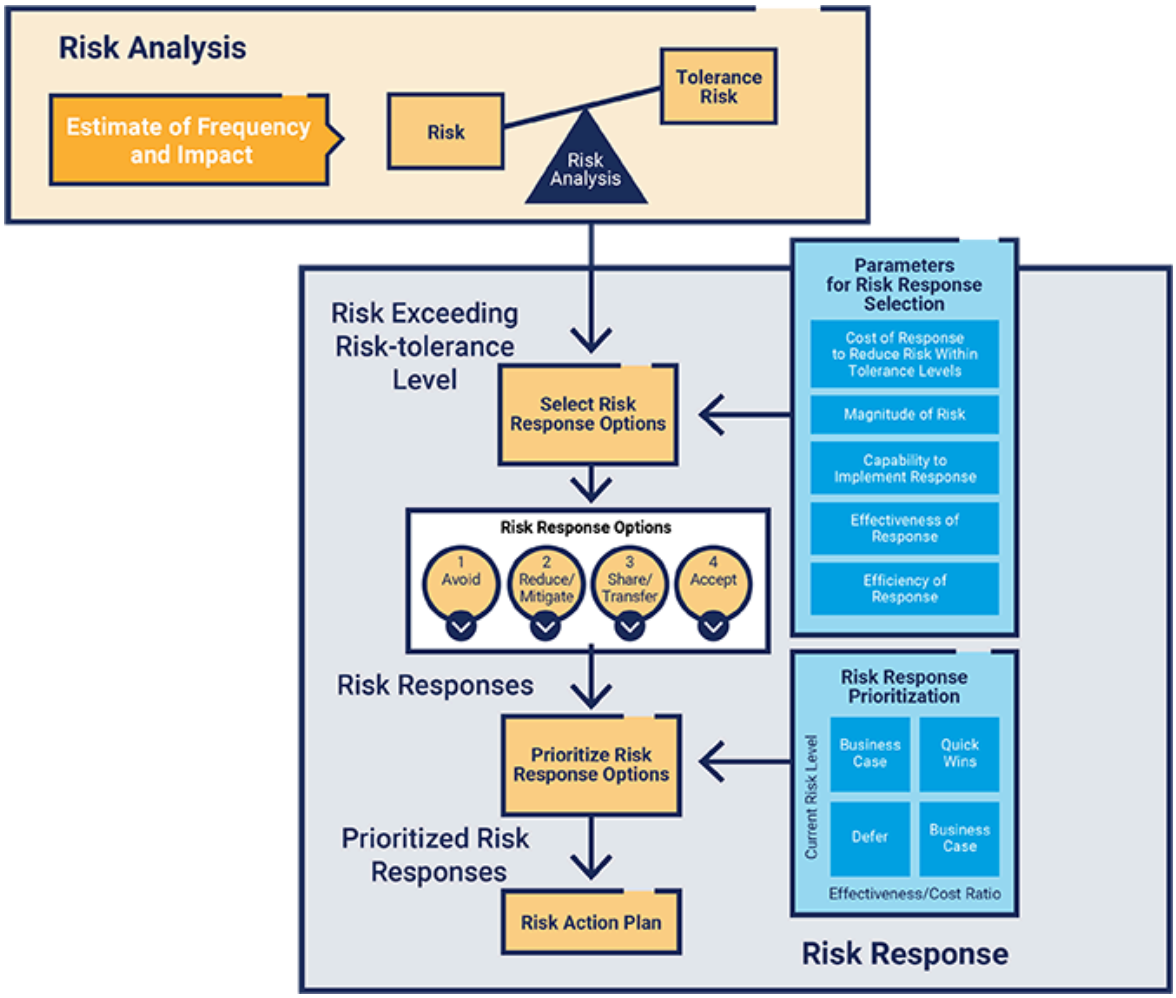
The decision to follow a particular course of action is based on many factors, including but not limited to:

- Current risk level
- Applicable laws and regulations
- Ongoing projects
- Strategic plans and management priorities
- Current and projected budgets
- Staff availability
- Public pressure
- Competitor actions

Risk action planning shown in **figure 3.14** reflects the following concepts:

1. Risk scenarios (from risk identification) drive the risk analysis and assessment.
2. Risk analysis (from risk assessment) leads to the documentation (mapping) of risk.
3. Risk response is determined by the risk appetite of the enterprise: risk within the appetite should be accepted, while risk that exceeds the appetite needs to be modified or avoided.
4. Where action beyond acceptance is needed, all options are considered to determine the best available risk response.
5. Risk responses are prioritized according to the current risk environment and cost-benefit analysis or another value-driven methodology.
6. A risk action plan is created to manage the risk response projects reviewed and approved by the risk owner and added to the risk register.

Figure 3.14—Risk Response Selection and Prioritization



Source: ISACA, *The Risk IT Framework, 2nd Edition*, USA, 2020

Risk response is subject to the strategic and technological direction of the enterprise, which can affect the selection (particularly the decision to transfer versus mitigate), the choice of one control over another, and its schedule for deployment.

Where mitigation is the chosen response, decisions can be difficult to make and often require some method of comparing control options. Questions that the risk practitioner should keep in mind include:

- Would the control be effective?
- Would the control provide sufficient ROI (or otherwise meet cost considerations)?
- Does the enterprise have sufficient skill to implement, configure, and maintain the control, both now and in the foreseeable future?
- Are there sufficient resources and time to implement the control?
- What would the impact of the control be on productivity?

Developing and implementing a risk action plan is best done as a project with a defined start and end date. Use of a project-planning mindset allows the risk practitioner to determine the critical path of the project, which refers to those elements of the project that may have a direct impact on whether the end date can be met. Understanding the critical path can help keep the project on track.

The risk practitioner should understand that changes in the delivery of any project element on the critical path affect the delivery of the entire project. For example, a project that does not receive its equipment from the supplier on time may not be able to meet scheduled completion dates. Critical path elements should be given special consideration because delays in these elements increase overall project risk.

Through experience and careful evaluation, the risk practitioner can closely monitor the critical path and regularly advise the risk owner on the feasibility of meeting the scheduled end date.

3.9 Data Collection, Aggregation, Analysis, and Validation

Key Takeaways

- Logs tend to gather a lot of data, which can be difficult to parse and analyze without specialized software.
- Security information and event management (SIEM) systems specialize in log analysis.
- Integrated test facilities can dramatically reduce production risk but may slow production processing.

Risk management tends to be data intensive. Often, the risk practitioner has a wealth of data sources available, including network devices, application logs, threat intelligence, and audit reports. Having data is valuable, but events may be hidden by sheer volume, leading to erroneous conclusions. It is therefore important that data not only be collected but also aggregated and managed in ways that facilitate its transformation into useful information.

The challenges of data analysis start with the completeness and trustworthiness of the data, summarized in these questions:

- Is all of the data available?
- Has any of the data been altered or changed?
- Is the data in the correct format?
- Is the data based on measuring important factors?

Some of the most common approaches to conducting data analysis are listed in **figure 3.15**.

Figure 3.15—Methods for Uncovering Less Obvious Risk Factors

Method	Description
Cause-and-effect analysis	A predictive or diagnostic analytical tool that is used to: • Explore the root causes or factors that contribute to positive or negative effects or outcomes • Identify potential risk **Note: A typical form is the Ishikawa or "fishbone" diagram.**
Fault tree analysis	A technique that: • Provides a systematic description of the combination of possible occurrences in a system, which can result in an undesirable outcome (top-level event) • Combines hardware failures and human failures A fault tree is constructed by relating the sequences of events that, individually or in combination, could lead to the top-level event, then deducing the preconditions for both the top-level event and the next levels of events, until the basic causes are identified (elements of a "perfect storm," or unlikely simultaneous occurrence of multiple events that cause an extraordinary incident) **Note: The most serious outcome is selected as the top-level event.**
Sensitivity analysis	A quantitative risk analysis technique that: • Helps to determine which risk factors potentially have the most impact • Examines the extent to which the uncertainty of each element affects the target object when all other uncertain elements are held at baseline values **Note: The typical display of results is in the form of a tornado diagram.**

When analyzing data to determine risk levels, the risk practitioner should be attentive to the trends of events in the data sources. Trends may reveal an emerging threat, but detection of threats that are not already known is possible only when regular analysis has already established a reliable baseline of what constitutes normal behavior. With a baseline established, deviations more easily draw attention.

3.9.1 Data Collection and Extraction Tools and Techniques

The risk practitioner may use various sources of data to monitor and report on risk. Common internal data sources include:

- Prior risk assessments
- Project documents, especially risk logs and documented lessons learned
- Tickets from change, problem, release, configuration, asset, and incident management systems

- Audit and incident reports
- User feedback and observation
- Interviews with management
- Security and test reports, including reports from continuity and recovery plan tests
- Event and activity logs
- An independent third-party accredited assessment report, certification, etc.
- Internal control reviews conducted by the risk practitioner

Operational staff frequently aggregate data from multiple sources for broader visibility. Aggregation can help make large volumes of data more manageable. However, aggregated data may obscure details present in individual sources. Risk practitioners searching for unusual activity should keep in mind that detailed analysis of original sources may reveal patterns not identifiable under aggregation. The increasing availability of AI tools for log analytics offers an alternative to traditional aggregation in which source data is reviewed for trends before being channeled upward as a summary of findings.

Data should also be validated to ensure its quality, including verifying that it is of the expected type, falls within plausible ranges, and has logical consistency across fields. For instance, data intended to present dates and times should not be text strings, and a delivery date should never be earlier than the order date. Where validation fails, the risk practitioner should investigate whether the problem arose from how the data was retrieved or is it present in the source itself. The former typically suggests a procedural problem, while the latter can indicate misconfiguration or even be an indicator of compromise.

Logs

Logging is commonly provided by systems, devices, and applications and remains the most consistently popular way to capture and store data for analysis. Analysis of log data can identify security violations and be instrumental in forensics investigations. Log analysis can alert the organization to malicious activity, such as a developing attack or multiple attempts to break in. Log data may be used to identify the source of an attack and assist in tailored strengthening of controls.

Logging has traditionally presented a trade-off between speed, detail, and utility. If a log contains too much data from too many sources, it may be difficult to notice significant individual events. Time synchronization of log entries can assist with correlation of events from multiple sources and improve the usefulness of review. Logging also takes time, potentially decreasing throughput for each transaction monitored. By understanding the ways in which log data is obtained, the risk practitioner is better able to anticipate the extent to which the data captured presents a complete picture of activity.

Analysis of log data and control activity should answer the following questions:

- Are the controls operating correctly?
- Is the level of risk acceptable?
- Are the controls aligned with the risk strategy, business strategy, and key priorities?
- Are the controls flexible enough to meet changing threats?
- Are the correct risk data being provided in a timely manner?
- Is the risk management effort benefiting corporate objectives (or at a minimum, not hindering them)?
- Is awareness of risk and compliance requirements reflected in user behavior?

As network and client security systems continue to mature, logging for specific purposes is becoming more granular and offers a greater degree of detail for analysis. For instance, client-resident data loss prevention (DLP) software can integrate with antivirus and anti-malware modules to distinguish between interactive (human) and process-driven (automated) attempts to migrate data in ways that are forbidden. Such information might reveal the difference between inadequate user training (or a malicious insider) and a remotely compromised system. Logging by intrusion detection or prevention systems (IDS/IPS) placed within the network can also be useful in detecting suspicious traffic patterns, particularly when combined with advanced behavior-based (heuristic) analysis. These capabilities are increasingly present in security

baselines of cloud hosting environments and can leverage vastly more processing power than was possible just a few years ago to identify patterns that localized analysis would not be able to detect.

Logs may contain information that is sensitive or needed for forensic purposes, so they should be configured in ways that prevent alteration or deletion and prevent access by authorized personnel. In particular, SoD should be implemented in ways that prevent administrators with responsibility for systems or applications from altering or deleting logs made against their own scopes of responsibility. The risk practitioner should consider log access permissions as part of evaluating the potential insider threat level.

Logs are one of the most valuable tools for monitoring controls and detecting risk, but they are often underutilized. Common challenges relating to the effective use of logs include:

- Having too much data
- Difficulty in searching for relevant information
- Improper configuration (e.g., may not be enabled or contain appropriate data)
- Modification or deletion of data before it is read (e.g., too little storage space)

An effective log should contain a record of all important events that occur on a system, such as:

- Changes to permissions
- System startup or shutdown
- Login or logout
- Changes to data
- Errors or violations
- Job failures
- Who (name/user ID) performed changes or modified the configuration
- Time when the event occurred

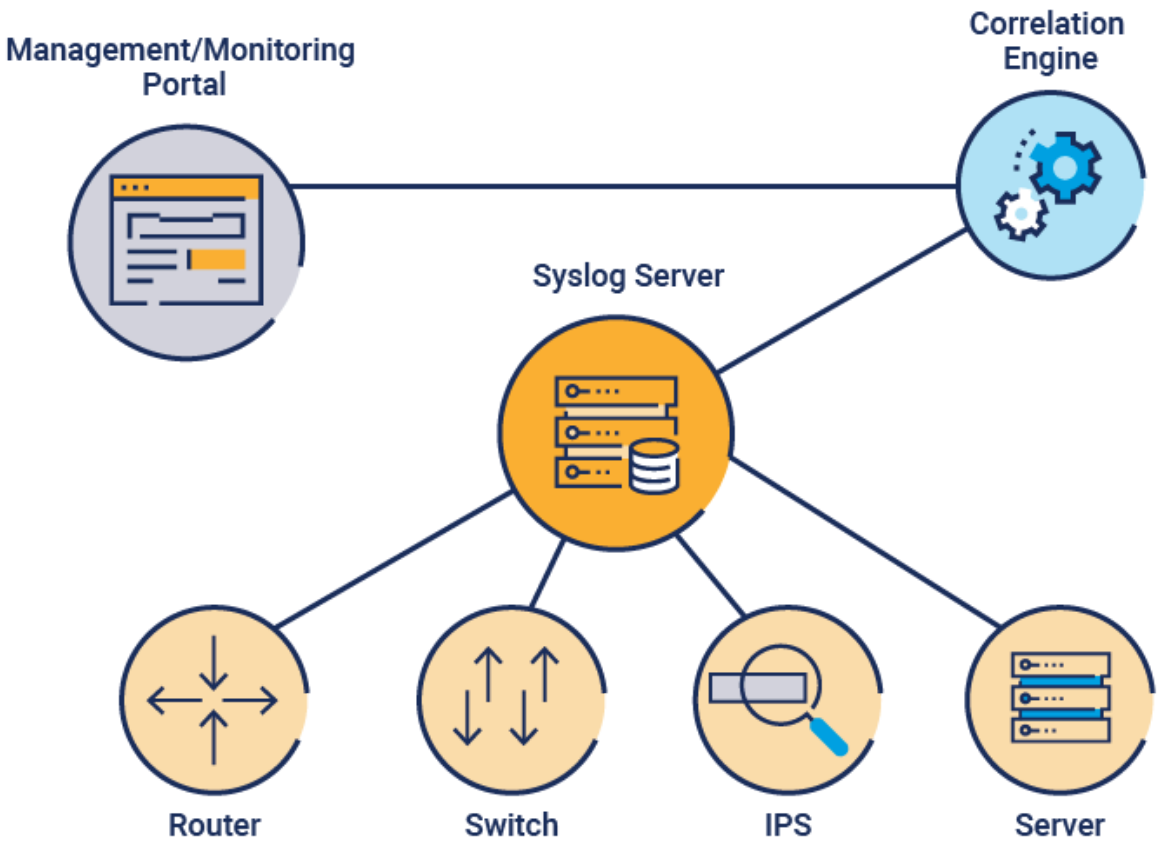
Log review is often the most effective and sometimes the only feasible way of detecting certain indicators of compromise. Log reviews identify risk-relevant events such as compliance violations, suspicious behavior, errors, probes or scans, and other abnormal activity. Conversely, failure to review logs can result in the enterprise not being aware of an ongoing attack. The risk practitioner may find it useful to employ analysis tools to filter pertinent data in logs. Advanced algorithms also exist that can rapidly parse log data and highlight activity that may warrant greater concern.

Because they provide a record of events as they occur, logs should be preserved for possible forensic analysis. Care should also be taken to ensure that logs cannot be changed on production systems.

Security Information and Event Management

Enterprise networks tend to grow over time. As the numbers of end points and routes expand, the risk practitioner may become overwhelmed by the sheer volume of data presented by logs and other individually based alerting mechanisms. SIEM systems are integrated data correlation tools that capture data from multiple sources and analyze activity at the system, application, and network levels for possible security events. SIEM systems can be used to detect attacks in progress by signature or behavior (heuristics), as well as identify compliance violations. **Figure 3.16** illustrates a notional SIEM architecture.

Figure 3.16—A SIEM System



The key to SIEM is the speed of the correlation engine. By gathering and correlating data from multiple sources, a SIEM system can develop reports on security at the enterprise level while retaining the ability to highlight relationships among activity on various parts of the network or systems. Correlation based on multiple criteria such as type, timing, chronological sequence, and identified source of an event are all commonly available in SIEM implementations. In many cases, assessment is possible even at very granular levels, including activities associated with specific transaction codes, network IDs, or types of traffic that may be generally permissible but are outside of common behavioral norms for the monitored network. SIEM is particularly effective in cloud environments where processing power can be provisioned on the fly to address particularly high analysis requirements in near-real time.

By highlighting developing trends, SIEM systems allow risk practitioners to identify risk and bring it to management's attention before it would typically be discernible at the level of individual logs. Some large organizations may also maintain their own security operations center (SOCs) that can perform additional correlation and analysis as well as near-real-time monitoring.

Detection and Response Technologies

Historically, endpoint security technologies such as signature-based antivirus tended to be reactive in nature, detecting perceived or potential security threats using signatures for known attack patterns. Endpoint detection and response (EDR) attempts to be predictive in nature, focusing on identifying threats and malware designed to evade traditional security defenses. Most EDR solutions will leverage some type of cyberthreat intelligence with possible machine learning (ML) capabilities in conjunction with file analysis and threat detection. EDR technologies should be implemented while also adjusting for baseline network activity to decrease false-positive alerts for legitimate business activity.

EDR solutions typically create a historical audit trail in which system and user behavior and security events are captured for follow-on analysis by security analysts. EDR solutions can not only help in incident response efforts but can also support root cause analysis. Some EDR technologies may also include the ability to recommend remediation actions to prevent future intrusions.

An evolved version of EDR, extended detection and response (XDR), takes a holistic approach to endpoint detection and response. As the name implies, detection and response efforts extend beyond the individual endpoint. XDR provides enterprise information security teams with a unified view across their endpoints and performs analysis of servers, cloud, and networks. XDR builds on the capabilities of EDR, leveraging automation, ML, and artificial intelligence (AI) capabilities to provide context around security events.

Managed detection and response (MDR) is a hybrid combination of technology and service provider. The business value is for those environments that lack both appropriate expertise and skills or have limited resources to monitor potential attack vectors adequately. Typically, the service provider is responsible for providing the security technology and managing enterprise deployments. Some MDR providers also provide incident response services, while others may only provide basic triage or investigate initial security alerts before alerting the enterprise to execute follow-on response and remediation actions.

Integrated Test Facilities

When seeking to monitor the performance and operation of an application, one common method is to use an integrated test facility (ITF). An ITF is a testing methodology that processes test data through production systems to test whether the systems are operating correctly. Within an ITF, the organization might set up several fictitious customers or transactions that are processed along with real data, allowing business analysts to observe the operation of the production systems and ensure correct processing. Enterprises that use an ITF need to ensure proper tracking of fictitious data to ensure that these test entries do not generate unintended downstream production activities.

External Sources of Information

Although internal sources provide the clearest picture of what is happening within the organization, the risk practitioner can gain additional insight by reviewing external data sources such as:

- Media reports
- Computer emergency (or incident) response team (CERT/CIRT) advisories
- Security company reports
- Regulatory bodies
- Peer organizations

Annual reports from antivirus, security, and telecommunications companies provide a summary review of risk and exposure factors observed in the field and may assist in developing and presenting risk management solutions to management. Information on incidents and risk may also come from computer or cybersecurity monitoring and reporting services by government and nonprofit organizations.

3.10 Risk and Control Metrics

Key Takeaways

- Not all indicators are key indicators.
- KPIs alert management that action is needed to meet performance targets.
- KRIs alert management that performance targets may be at risk.
- KCIs reveal the performance of specific controls.

Measuring and monitoring the performance of risk and controls over time is a key part of the risk management life cycle. Developing meaningful metrics is an efficient means by which to monitor the status of current and emerging risk, the effectiveness of controls, and potential materialization of risk. The three most common metrics used in risk and control monitoring are KPIs, KRIs, and KCIs.

3.10.1 Key Performance Indicators

Performance indicators measure how well a process is performing in terms of its stated goal. This measurement provides insight into whether action may be required, with the goal of allowing changes to be made before significant impacts occur. Although many indicators loosely correlate with performance, a subset of these indicators are effective in predicting whether organizational goals will be reached and indicates the capabilities, practices, and skills of value to the organization. These closely correlated performance indicators are called KPIs.

KPIs measure activity goals, which are actions that process owners must take to achieve effective process performance. They are commonly used to set benchmarks for risk management goals and to monitor whether those goals are being attained. Management sets its risk management goals according to its risk acceptance level and desired cost-benefit analysis. For example, a KPI may indicate that an error rate of five percent is acceptable, which implies that an error rate higher than five percent is unacceptable and requires escalation with some form of response.

A KPI should be based on SMART metrics:

- **Specific**—Based on a clearly understood goal; clear and concise
- **Measurable**—Able to be measured; quantifiable (objective), not subjective
- **Attainable**—Realistic; based on important goals and values
- **Relevant**—Directly related to a specific activity or goal
- **Timely**—Grounded in a specific time frame

Additionally, KPIs should be:

- Valuable to the enterprise
- Tied to a business function or service
- Under the control of management
- Quantitatively measured
- Usable in different reporting periods (for consistency)

Examples of potential KPIs include:

- Network availability
- Customer satisfaction
- Number of complaints resolved on first contact
- Time between data request and presentation
- Number of employees that attended awareness sessions

KPIs place emphasis on processes that should be good indicators of the health of the overall process. They are often used on charts or graphs to report compliance to management in a clear, easily understood manner, and have long been included in balanced scorecard reporting.

3.10.2 Key Risk Indicators

Risk indicators are used to measure risk levels against defined risk thresholds, so that the organization receives an alert when a risk level approaches an unacceptable level. By having tracking and reporting mechanisms in place that alert staff to a developing or potential risk, the enterprise gains the opportunity to respond to the risk before it produces unacceptable outcomes.

KRIs comprise a subset of risk indicators that are highly relevant and likely to predict or indicate important risk. Examples of KRIs may include:

- Number of unauthorized endpoints or software licenses detected in scans
- Number of instances of SLAs exceeding thresholds

- High average downtime due to operational incidents
- Average time to deploy new security patches to servers
- Excessive average time to research and remediate operations incidents
- Number of desktops/laptops that do not have current antivirus signatures or have not run a full scan within scheduled periods

KRIs support numerous aspects of risk management, including:

- **Risk appetite**—Validating the enterprise's risk appetite and risk tolerance levels
- **Risk identification**—Providing an objective means for identifying risk
- **Risk mitigation**—Providing a trigger for investigating an event or providing corrective action
- **Risk culture**—Helping the enterprise focus on important, relevant areas
- **Risk measurement and reporting**—Providing objective and quantitative risk information
- **Regulatory compliance**—Providing data that can be used as an input for operational risk capital calculations

KRI Selection

KRIs should be selected carefully and sparingly. Common mistakes made when implementing KRIs include classifying too many risk indicators as being KRIs and choosing KRIs that are flawed in some way. These include those KRIs that:

- Are not linked to specific risk
- Are incomplete or inaccurate due to unclear specifications
- Are difficult to measure, aggregate, compare, and interpret
- Provide results that cannot be compared over time
- Are not linked to goals

The effectiveness of KRIs depends in large part on the strength of their metrics. As with KPIs, KRIs should leverage SMART metrics. Other factors that can influence the selection of KRIs include:

- **Balance**—The set of selected risk indicators should include:
  - Lagging indicators (indicating risk after events have occurred)
  - Leading indicators (indicating which controls are in place to prevent events from occurring)
  - Trends (analyzing indicators over time or correlating indicators to gain insights)
- **Root cause**—Selected indicators should drill down to the root cause of events, not just the symptoms.

The selection of an appropriate set of KRIs benefits the organization by:

- Providing an early warning signal that a high risk is emerging, allowing management to take proactive action before the risk creates negative impact
- Providing a backward-looking view on risk events that have occurred, enabling risk responses and management to be improved
- Enabling the documentation and analysis of trends
- Providing an indication of the enterprise's risk appetite and tolerance through metric setting (i.e., KRI thresholds)
- Increasing the likelihood of achieving the enterprise's strategic objectives
- Assisting in continually optimizing the risk governance and management environment

When working with management to determine appropriate KRIs, the risk practitioner should work with relevant stakeholders to promote greater buy-in and ownership. Risk indicators should be identified for all stakeholders, and IT-based metrics should be aligned with other metrics used in the enterprise to the greatest extent possible.

KRI Effectiveness

KRI effectiveness takes into consideration the following criteria:

- **Impact**—Indicates risk with high business impact
- **Effort**—Is the easiest to measure and maintain among indicators of equivalent sensitivity
- **Reliability**—Possesses a high correlation with the risk and is a good predictor or outcome measure
- **Sensitivity**—Is capable of accurately indicating risk variances
- **Repeatable**—Can be measured on a regular basis to show trends and patterns in activity and results

KRI Optimization

To ensure accurate and meaningful reporting, KRIs should be optimized to ensure that the correct data is being collected and reported on and thresholds are set correctly. KRIs that report on data points that either cannot be controlled by the enterprise or are not alerting management to an adverse condition at the correct time should be adjusted to be more precise, relevant, or accurate.

Figure 3.17 describes examples of KRI optimization.

Figure 3.17—Examples of KRIs Optimized for Management

Metric Criterion	Example
Sensitivity	Management has implemented an automated tool to analyze and report on access control logs based on severity, and the tool generates an excessive number of results. Based on a risk assessment, management directs that the monitoring tool be configured to report only on alerts marked “critical.”
Timing	Management has implemented strong separation of duties (SoD) within the enterprise resource planning (ERP) system. One monitoring process tracks system transactions that violate the defined SoD rules before month-end processing, so that suspicious transactions can be investigated prior to the generation of reconciliation reports.
Frequency	Management has implemented a key control that is performed multiple times a day. Based on a risk assessment, management decides that the monitoring activity can be performed weekly because this will capture a control failure in sufficient time for remediation.
Corrective action	Management has implemented a remediation process to bring controls into alignment with the organizational risk appetite. Using existing problem management tools, management is able to integrate automated monitoring of the controls into the process to prioritize existing gaps, assign problem owners and track remediation efforts.

KRI Maintenance

Because the organization's internal and external environments are constantly changing, the risk environment is also highly dynamic. KRIs should be evaluated on a regular basis to verify that each indicator remains properly related to the risk appetite and tolerance levels of the enterprise and that trigger levels are defined at points that allow stakeholders to take appropriate action in a timely manner. Any KRIs that are no longer related to the risk appetite and tolerance should be replaced, while any with trigger levels that are found to be out of alignment with the requirements of the enterprise should be optimized.

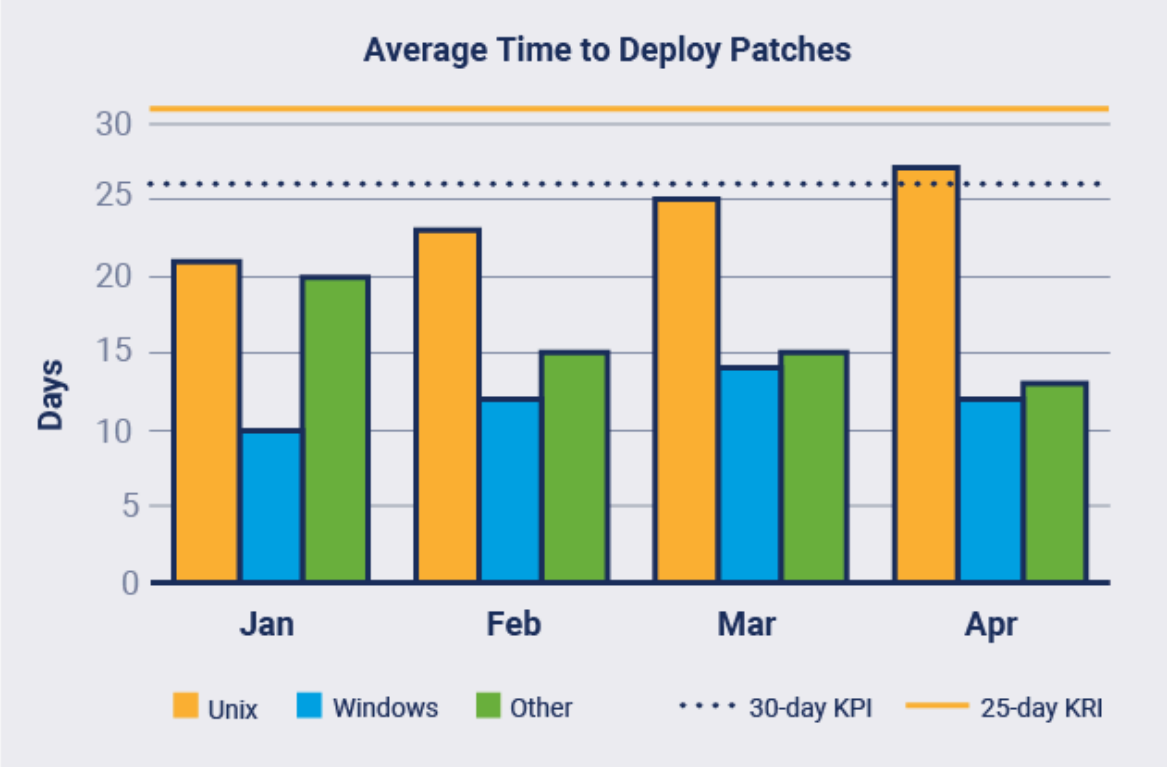
3.10.3 Using KPIs With KRIs

KPIs and KRIs are often used in conjunction with one another to measure performance and mitigate risk. KPIs help to identify underperforming aspects of organizations and areas of the business that may require additional resources and attention, while KRIs provide early warnings of increased risk within the enterprise. Failing to meet performance goals is itself a risk, so the two can be used together in risk management or combined with indicators specific to controls that may foreshadow an increase in risk due to a decrease in the effectiveness of mitigation.

To illustrate the difference, consider the risk that unpatched systems may lead to a serious breach of customer data, loss of availability, and financial loss. In response to this risk, the organization develops a policy to apply all critical patches within 30 days. The development of this policy is an example of a KPI: the enterprise has a clear, measurable standard of what constitutes proper performance. On a scheduled basis, the enterprise tracks and reports to senior management on whether that KPI has been met and reports on the average time to deploy critical security patches.

If an organization tracks the time between the release of a patch and its deployment within the organization monthly, then a report that shows the average time taken could be developed, as shown in **figure 3.18**.

Figure 3.18—Example of Reporting KRIs and KPIs



Through this chart, a manager can see that the time to deploy patches on a UNIX system is increasing each month and is in danger of exceeding the 30-day threshold. To detect a trend or developing problem, the organization may also set a KRI representing a threshold or level of performance that is getting

dangerously close to exceeding the KPI but has not yet done so. By setting a KRI of 25 days, management can see that the time to deploy a UNIX patch has now increased to the point of triggering an alert. This alert should precipitate a review of the UNIX patching procedures, and management should investigate the situation to enable preventive action and address the slow deployment process before the deployments of these patches violates the policy.

The example above shows how KRIs and KPIs can be used to monitor and track the attainment of goals. When measuring the success of a risk management program, KPIs must be based on meaningful criteria that can help management track the overall success of the controls put in place to support risk response.

3.10.4 Key Control Indicators

Certain indicators can be used to reveal the effectiveness of controls. Of these, the subset that quantifies how well a specific control is working constitutes the set of KCIs. The goal of KCIs is to track performance of control actions relative to tolerances, providing insight into the ongoing adequacy of a given control in keeping risk within acceptable levels. For this reason, they are sometimes called control effectiveness indicators.

Examples of KCIs include:

- Phishing emails not blocked by filtering systems (indicating a weakness in features or tuning and foreshadowing a higher risk of compromise linked to phishing)
- Administrators with rights to both test and production environments (indicating a weakness in procedures intended to establish and maintain segregation of duties)
- Unsolicited prompts for second-factor authentication (indicating a weakness in password security, allowing would-be hackers to reach the second stage of authentication)

Each KCI has its own tolerances based on the underlying assets that its controls protect and the impact to the organization associated with their loss or compromise. Because controls affect risk, KCIs are correlated not only with specific controls, but also with the risk that those controls are meant to mitigate. As a result, KCIs tend to be leading indicators for KRIs associated with the controls that they monitor: where tolerances are broken, the KCI reveals an increasing risk exposure that will eventually be represented in the KRIs associated with the monitored control.

This correlation also means that all KCIs are themselves risk indicators; however, they rarely rise to the level of being KRIs in their own right, tending instead to be secondary indicators of risk arising from control failure or nonperformance. Additionally, because individual controls may affect multiple risk areas, KCIs may have broader implications than KRIs.

3.11 Risk and Control Monitoring Techniques

Key Takeaways

- Controls should be regularly or continuously monitored.
- Vulnerability assessments test controls and systems against known weaknesses.
- Penetration testing seeks to determine whether unknown vulnerabilities may exist by using the methodologies of malicious actors, which is risky.
- No penetration testing should be done without clearly defined rules and the explicit approval of senior management.

To support the ability to monitor and report on risk, the risk practitioner should ensure that processes, logs, and audit hooks are commonly placed into the control framework, which allows for the monitoring and

evaluation of controls. As controls are designed, implemented, and operated, the risk practitioner should ensure that logs are enabled, controls are testable, and regular reporting procedures are developed.

The actual monitoring and reporting of controls should be performed in the risk monitoring phase of risk management; however, the risk practitioner should ensure that the capability to monitor a control and support monitoring systems is addressed in control design. If the organization is using a managed security service provider (MSSP) or a SIEM system, the functionality to capture data and notify operations staff when specific triggers are activated will need to be considered.

3.11.1 Monitoring Controls

To prevent an IT risk that exceeds the enterprise's risk acceptance criteria, risk monitoring, and evaluation should be integrated with enterprise performance management systems to ensure alignment between IT risk and business risk. The controls mandated through risk management must be aligned with IT security and related enterprise policies and subject to a regular process of review and revision to ensure that IT policies support the requirements of the enterprise.

To that end, the risk practitioner should work with stakeholders to first set up an IS control monitoring process that reflects objectives, scopes, and methods consistent with enterprise objectives and then integrate this approach with performance management at the enterprise level. The purposes of the IS control monitoring function are to ensure that IT security requirements are being met; standards are being followed; and staff members are complying with the policies, practices, and procedures of the enterprise.

Monitoring controls is a process that has six steps:

1. Identify and confirm risk control owners and stakeholders.
2. Engage with stakeholders and communicate the risk and information security requirements and objectives for monitoring and reporting.
3. Align and continually maintain the information security monitoring and evaluation approach with IT and enterprise approaches.
4. Establish information security monitoring processes and procedures.
5. Determine life cycle management and change control processes for information security monitoring and reporting.
6. Request, prioritize, and allocate resources for monitoring information security.

The purpose of a control is to mitigate risk, so controls are monitored to verify whether they are effectively addressing risk, not simply to see whether the controls themselves are working. For example, a firewall that is configured in a way that does not regulate traffic between two networks may be ineffective, even if it is operational.

Risk monitoring and evaluation are processes performed to:

- Collect, validate, and evaluate enterprise, IT, and process goals and metrics.
- Monitor processes to ensure that they are performing in line with established performance metrics.
- Provide reports that are systematic and timely.

To accomplish these tasks, data related to risk management must be gathered from various sources in a timely and accurate manner. After the data has been validated for integrity, analysis can be performed against specific performance targets. Properly done, this process provides a succinct, holistic view of IT performance within the enterprise monitoring system.

The risk practitioner should continuously monitor, benchmark, and improve the IT control environment and control framework to meet organizational objectives. When the results of the monitoring indicate an area of noncompliance or unacceptable performance, the risk practitioner should recommend mitigation activities such as implementation of new controls, adjustment or enforcement of existing controls, or changes to a business process to address the risk environment.

The monitoring of controls and the risk management framework may be done through self-assessment or independent assurance reviews. Risk action plans should be monitored to ensure appropriate risk management practices in alignment with risk appetite and tolerance. Assurance activities should be kept separate from the function, group, or organization being monitored, and those responsible for assurance should have the necessary skills and competence to perform assurance and adhere to codes of ethics and professional standards.

Any exceptions to risk monitoring and control activities should be reported promptly, analyzed, and addressed with properly prioritized corrective actions. As the risk environment changes and internal control systems are affected by changes in enterprise and IT risk, gaps in the risk environment should be evaluated so that changes can be made where necessary.

Sources of control monitoring information include:

- Network operations centers (NOCs)
- SOCs
- Command and control centers
- Continuous control monitoring
- Periodic testing
- Independent assessments

The risk practitioner should encourage each process owner to take ownership of control improvement through a program of regular self-assessment to evaluate the completeness and effectiveness of management's control over processes, policies, and contracts. In addition, explicit acknowledgment by management that all monitoring activities are functioning as designed should be recorded in the risk registry on a regular basis.

3.11.2 Control Assessment Types

Effective control monitoring depends on the accuracy and completeness of the data provided for evaluation. To be able to draw correct conclusions from the data analysis, the risk practitioner must ensure that the data received has been generated from the true and correct source. Data retrieved directly by the risk practitioner (or under direct observation) are preferable to data provided by a third party. The risk practitioner should encourage local ownership of risk and control monitoring, which helps instill a risk culture in which local managers accept responsibility for risk, which in turn may enable faster detection of violations and security incidents.

Self-assessment

Controls are most easily assessed by those who regularly interact with them as part of their job functions. Through facilitated workshops, surveys, or sampling methods, operational staff can determine the general effectiveness of controls on a recurring basis. In time, these self-assessments establish baselines that can be used to highlight deviations that may indicate control weaknesses or failures. Self-assessment is included in methodologies promulgated in NIST, COBIT, and COSO frameworks.

IS Audit

Audit teams provide independent and objective review of the effectiveness and appropriateness of the control environment. Information provided by IS auditors can underline the need for control enhancement and bring risk to the attention of management along with strong supporting evidence. Recommendations provided by IS audit often require the attention of the risk practitioner through the updating of risk treatment plans, the risk register, and enhancement of controls. By providing supporting data to audit teams and working closely with them, the risk practitioner can better align the risk management program with the audit program.

Mechanized or automated assessment by an independent application is an emerging form of IS audit for technical controls that has the potential to revolutionize the process. Under this approach, a dedicated, secure capability for technical evaluation operates in parallel to the production process, evaluating 100% of control actions in near-real time based on predefined criteria. Operating in a manner analogous to an intrusion detection system, automated assessment generally does not impede the flow of production traffic and can generate alerts when control failures are detected.

Vulnerability Assessment

A vulnerability assessment is a methodical review of security to ensure that there are no predictable attack vectors (such as unnecessary open ports or services) that could be used to compromise an environment, either intentionally or unintentionally. The scope of an assessment may range from a single system or application to an entire facility or end-to-end business process. The purpose of the assessment is to deliver information to management that can be used both to understand the effectiveness of the risk management program and to make decisions regarding treatment of identified vulnerabilities, such as deploying new controls.

A risk practitioner participating in a vulnerability assessment should have a working knowledge of both the technical and nontechnical security controls in the environment and the overall architecture. For example, a review of a firewall may include the configuration, the change control process for managing the configuration, the process for monitoring the firewall logs, the system architecture that ensures the firewall cannot be bypassed, and the training and competence levels of the firewall administrators. There are many open-source and commercial tools that can be used to automate or supplement the vulnerability assessment process. Additionally, many websites list known vulnerabilities with common applications, operating systems (OSs), and utilities.

Risk practitioners should be careful to avoid the trap of reliance upon automated tools, particularly when assessing vulnerability of IT systems. Vulnerabilities identified by an assessment may be false positives or may be addressed by compensating controls, and genuine vulnerabilities may be accepted by management if the only available mitigation strategies cost more than the potential impact of compromise. In addition, even the most rigorous vulnerability assessment is limited to weaknesses that are either generally known or can be discerned by the assessor based on the information at hand, while new methods of compromising systems are continuously being discovered.

Nonetheless, vulnerability assessment is an important tool in the risk management process. A remarkably high percentage of system compromises are based on exploitation of known vulnerabilities, including some that have patches available for deployment. Choosing to leave a vulnerability unpatched is a legitimate management decision, but it should be made consciously and documented as an acceptance of risk. Without the benefit of regular, rigorous vulnerability assessment, organizations may unwittingly embrace levels of risk beyond their risk appetite and risk tolerance.

Penetration Testing

A penetration test is a targeted attempt to break into an environment. As with a vulnerability assessment, the target of a penetration test may be a system, application, facility, or end-to-end business process.

If the goal of a penetration test is to validate a vulnerability assessment, the tester is typically given the results of the assessment in order to focus on the vulnerabilities that have already been identified. If the penetration tester is able to break in, then the vulnerability is real; otherwise, the vulnerability may be a false positive or adequately addressed by a compensating control, in which case further action may be unnecessary. This validation-centric approach is typically called a white box penetration test.

Penetration tests can also be undertaken against systems believed or claimed to be secure. When testing the effectiveness of the security associated with these types of systems, the tester is generally given no information beyond a limited number of ground rules for the engagement and a definition of what constitutes a successful compromise. In carrying out their work, a penetration tester given such a task often

uses the same tools used by malicious hackers to try to break into systems, so this is called black box penetration testing. A group on a long-term engagement attempting to penetrate security mechanisms using black-hat methods, whether external to the organization or established from its own staff, is commonly called a red team. This designation contrasts with the blue team, the proactive cybersecurity defenders of the organization who confront both red team and real-world adversaries.[37]

Penetration testing provides meaningful results, but the methods used may pose a risk to the enterprise in the form of system failure or data compromise. Therefore, it is of utmost importance that such tests—whether white or black box—are conducted only with management approval, using a defined methodology and under proper oversight. It is also important that the results of penetration testing be used as the basis for improvement, which is what distinguishes a penetration test from a practical audit. In environments where a Red Team operates, this improvement can be made nearly continuous through active engagement between the red and blue teams to review lessons learned—a partnership sometimes called a purple team to denote mutual, combined commitment.

Advances in AI, specifically generative AI (Gen AI), could potentially revolutionize penetration testing. AI models can be trained to mimic the actions of threat actors and could attempt various methods of attack in rapid succession, revealing vulnerabilities in controls that otherwise appear to be effective. However, a limitation is difficulty in teaching an AI system how to anticipate the potential effects of an action in order to remain within agreed-upon rules of engagement. Likewise, malicious actors can benefit from these tools due to a lack of safeguards around them. Risk practitioners and cybersecurity professionals should anticipate the use of Gen AI tools for both penetration testing and attempts to compromise systems.

Third-party Assurance

In many industries, an enterprise can earn customer and shareholder confidence by having a third party provide assurance or attestation of the validity of the information security program. Third-party attestation may be based on an external IS audit or a certification of compliance with an internationally recognized or industry standard, such as COBIT, PCI DSS or ISO/IEC 27001:2022. The third party is responsible for evaluating the processes of the subject enterprise and validating compliance with the requirements of the standard, after which the organization may display its compliance to meet customer requirements or gain competitive advantage.

Another source for attestation is based on SSAE 18, developed by the American Institute of Certified Public Accountants (AICPA). SSAE 18 standardizes System and Organization Controls (SOC) reports across three levels intended for different audiences, with varying levels of information disclosure based on sensitivity. This form of third-party assurance is used by many enterprises when relying on cloud or third-party service suppliers, where regular or continuous monitoring is particularly important to establish stakeholder confidence in the services being delivered outside the control of the organization but an individual right to audit is impractical. Delivery of an SSAE 18 report gives confidence to customers who may not themselves be permitted to assess the provider that the third party has done such an evaluation and confirmed that promised safeguards and practices are in place.

3.12 Risk and Control Reporting Techniques

Key Takeaways

- Risk should be regularly reported to management.
- Heat maps are visually appealing but of limited value with qualitative data.
- Stoplight charts can be effective when management has adequately defined upper and lower bounds for something to be marked “yellow.”

Risk practitioners are commonly expected to provide regular reports to management and the board of directors on the status of the risk management program and the overall risk profile of the enterprise. Making such a report requires a review of the effectiveness of the controls in the enterprise and their compliance with established policy. Controls may need adjustment, replacement, or removal depending on the changes in the risk environment and the acceptance and appropriateness of the controls.

The effectiveness of control monitoring is dependent on the following:

- **Timeliness of the reporting**—Is data received in time to take corrective action?
- **Skill of the data analyst**—Does the analyst have the skills to properly evaluate the controls?
- **Quality of monitoring data available**—Is the monitoring data accurate and complete?
- **Quantity of data to be analyzed**—Can the risk practitioner find the important data amid all the other log data available?

In addition, control owners may expect reports specific to their areas of accountability.

The channels best suited to reporting at different levels will depend on the preferences of those receiving the information and may vary from one risk owner to another. The essential element of the risk practitioner's internal risk reporting obligations is that the information presented be clear, useful, and timely, not that it adheres to a particular format. However, certain basic formats are commonly used in reporting risk, including heat maps, scorecards, and dashboards.

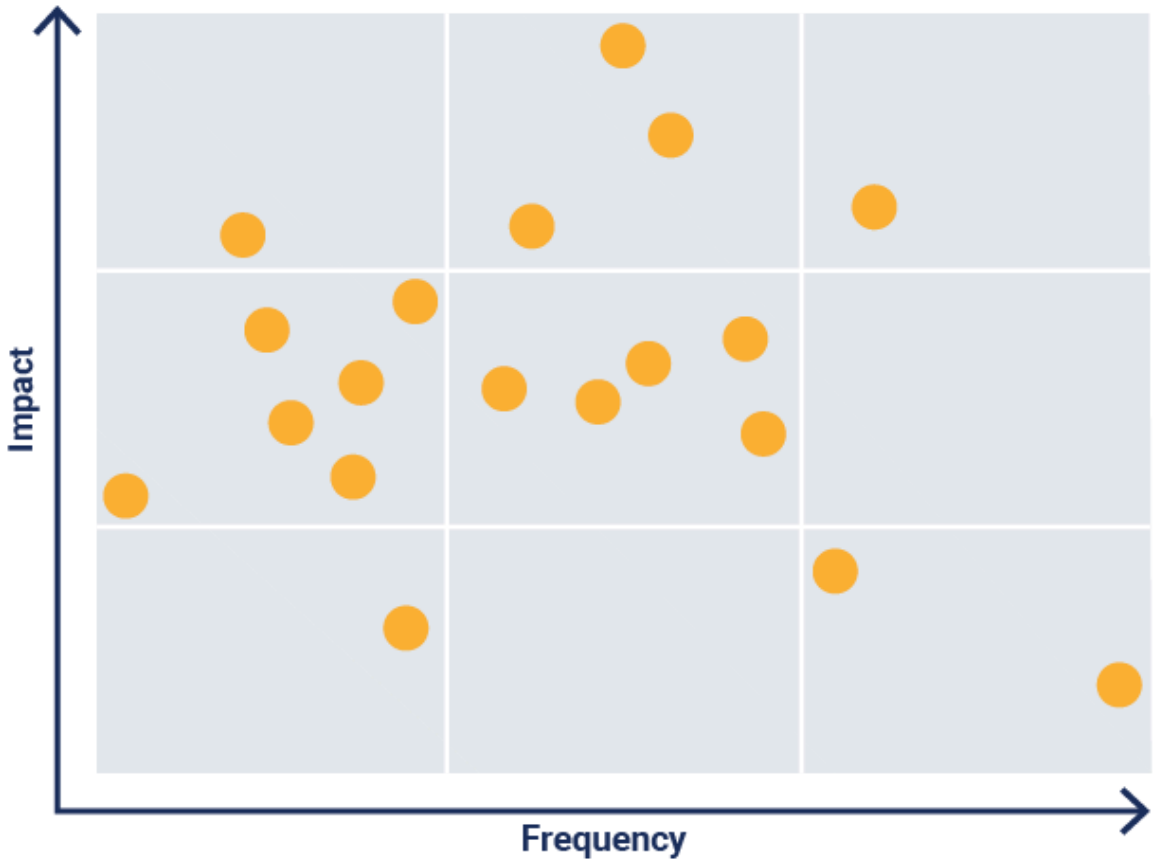
3.12.1 Heat Maps

The goal of a heat map is to create a graphical representation of risk distribution across a particular scope, which might be a department, system, or enterprise. The map itself is a scatterplot of data points against an X axis representing frequency and a Y axis representing impact. Only positive values are shown, so the bottom left corner of the map is the origin (0,0). The plot is then divided into squares, which may be 2×2, 3×3, 4×4, etc., with the bottom left square typically shaded green, while the upper right square is red. Between these extremes, squares are shaded in intermediate colors, making it apparent which (or how many) risk elements are at higher levels of impact, frequency, or both.

Although visually attractive, heat maps based on qualitative assessment methods are widely regarded as having minimal informational value, because qualitative data typically cannot be meaningfully aggregated. However, they can be useful as a means of expressing the effectiveness of controls within an overall architecture, localizing rates of compromise to particular areas or presenting quantitative results. It is essential for a heat map to make clear what it is presenting in terms of its underlying data, so that viewers can understand any practical limitations on the conclusions that can be drawn from it.

Figure 3.19 shows an example of a heat map.

Figure 3.19—Example Risk Map



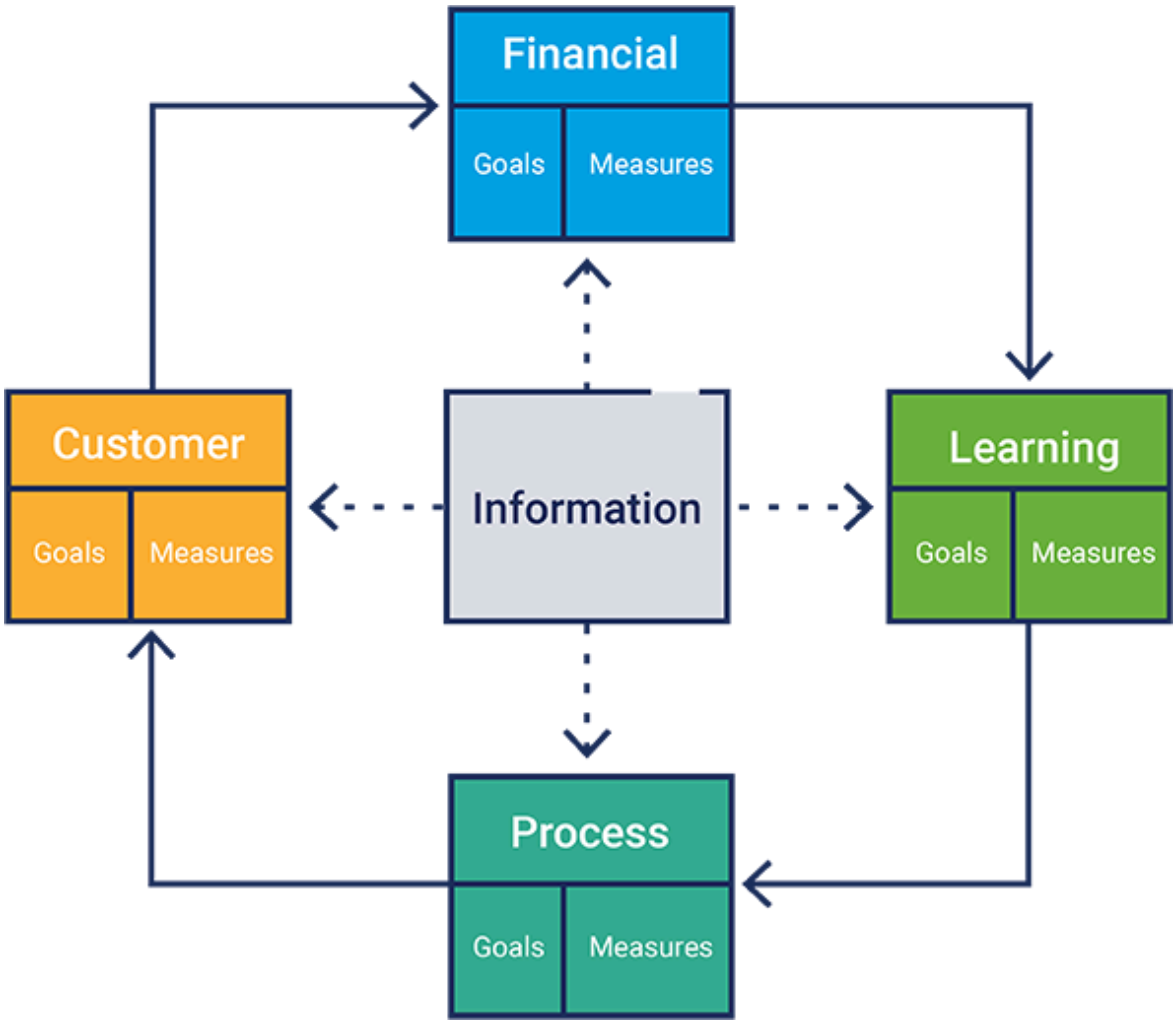
Source: ISACA, *Risk IT Practitioner Guide, 2nd Edition*, USA, 2020

3.12.2 Scorecards

Similar to academic grade reports, risk scorecards seek to simplify risk reporting by aggregating performance within particular functional areas and assigning grades or scores to each area. Scoring is typically done in a manner that reflects alignment with the enterprise risk appetite, although other baselines are possible. The original model for a risk scorecard suggested keeping risk and performance in distinct channels of reporting. Modern enterprise scorecards tend to incorporate risk indicators alongside the four main areas of the classic business balanced scorecard: financial, internal enterprise processes, learning and innovation, and clients and stakeholders. This approach unifies considerations of risk and performance against the backdrop of the overall strategic business context.

As with heat maps, scorecards are susceptible to biases in data arising from the limitations of qualitative assessments, whose results are not easily aggregated. This limitation can be somewhat mitigated by having a rigorous and effective process for identifying KRIs. **Figure 3.20** shows the dimensions of the classic balanced scorecard, where risk indicators might be added alongside performance indicators as part of the measurements for each area.

Figure 3.20—Balanced Scorecard Dimensions



Source: ISACA, *Board Briefing on IT Governance, 2nd Edition*, USA, 2003

3.12.3 Dashboards

When data is presented sequentially with distinct indicators for each item, the presentation is commonly called a dashboard. Values assigned to each dashboard item may be numeric scores, color-coded "stoplight" indicators, or a combination of the two. The intent is to allow rapid focus on those items that are falling outside acceptable levels. In practice, the effect of a dashboard tends to be elimination of focus from anything that fails to draw sufficient attention.

As with a heat map, a dashboard is limited by the perception that aggregate risk adheres to particular statuses intended for isolated analysis: two "yellow" items may be vastly different but receive the same attention. This perception is accurate for quantitative values but less reliable when assessments are qualitative in nature, as many tend to be. Risk practitioners should take care to understand the underlying data used to create stoplight charts and other forms of risk dashboard, so that senior managers reviewing these presentations can be made aware of their limitations and implications. Where the upper and lower bounds of a "yellow" indicator are well understood and accepted by management, the imprecision of exact values can be offset, even for qualitative data.

Metrics reported on dashboards or by similar means should be measured on a consistent, recurring basis (e.g. quarterly) to facilitate trend identification and analysis. Response actions associated with particular metrics should also be clearly documented. **Figure** 3.21 shows an example of a typical risk dashboard.

Figure 3.21—Risk Dashboard

Source: InetSoft, "OEM Case Study: Take Control of Your Enterprise Governance, Risk and Compliance," https://www.inetsoft.com/solutions/risk_management_reporting/. Source image courtesy of Protecht.

3.13 Monitoring and Reporting of Emerging Risk

Key Takeaways

- Risk changes over time because underlying conditions change as human societies develop new technologies and behavioral trends.
- Emerging technologies may introduce previously infeasible threats, such as the ability of deepfake voice and video to convincingly imitate a senior manager.
- When new threats emerge, controls that were once effective may need to be updated or even lose effectiveness altogether.

Risk is fundamentally dynamic because it arises from uncertainty. New areas of risk are always evolving, and even the most well-developed risk management program must operate on a continuous basis to be effective. Both the deployment of new controls and the introduction of new technologies have the potential to contribute to emerging risk.

The risk practitioner should understand the distinction between emerging risk and emerging technology. While emerging technologies are an example of emerging risk, the evolving risk and threat landscape encompass changes to legal and regulatory requirements, political change, social and environmental considerations, and changes to the business itself.

See section 4.7 Emerging Technologies for a discussion of specific evolving technologies impacting the risk environment.

3.13.1 Vulnerabilities Associated With Controls

Any changes that deal with controls should be carefully considered. This includes both the addition of new controls and modification of existing controls. Beyond their intended benefit to the enterprise, new or updated controls may also introduce new vulnerabilities. For example, an access control system that protects against unauthorized access may inadvertently deny access to legitimate users who forget passwords or lose access cards, resulting in calls for technical assistance, delays in processing, and user frustration. Modified controls may also not perform as expected, potentially reducing their effectiveness. The risk associated with deploying a particular control may even exceed the risk that it is meant to mitigate, as can sometimes be the case with early adoption of unproven technologies or changes to procedures that eliminate quality-control functions in the name of efficiency.

Enterprises should coordinate with stakeholders on a proactive basis and perform rigorous UAT under conditions as close to real-world use as possible prior to full implementation of any additions or changes to the control baseline. Additionally, technical staff should be alert for patches and other updates made available for technical controls and see that these are deployed as soon as they have been adequately tested, but no sooner. Bypassing testing could introduce new vulnerabilities or even directly threaten production systems if new features prove incompatible with other elements of enterprise information systems.

Therefore, it is important for the risk practitioner to not only continue to monitor and report on the risk addressed by the control in question, but also any emerging risk that may result from the modification.

3.13.2 Impact of Emerging Technologies on Design and Implementation of Controls

Many enterprises proactively adopt new technologies in an attempt to gain or maintain a competitive advantage. Managing risk in a highly dynamic environment requires the risk practitioner to be alert to the development of new technologies and proactive in assessing the risk of their incorporation into the enterprise. In some cases, eagerness to bring in new technology may get ahead of policies put in place to govern the process of technical adoption, setting the stage for unknowingly accepting risk outside the risk appetite. This is of particular concern when adoption occurs informally (sometimes called shadow IT) or on the authority of local managers who are not empowered to accept the commensurate risk.

Automated network scanners and other tools can be useful to detect unauthorized implementations of new devices or technologies that have not yet been reviewed and approved for use. Staff should also understand the processes required to submit a new technology for consideration, and any exceptions to full evaluation should be documented and approved by management. People typically want to stay within the rules, and where procedures to submit a technology for consideration are clearly communicated and fully understood, the risk of shadow IT tends to be less than in more opaque environments. This may be especially important in a time of digital transformation, where processes are increasingly automated or occur through networked means. Where alternate channels exist for data movement, organizations may find that their risk profiles have expanded far beyond expectation.

Emerging technologies can have significant effects on the design and implementation of controls. Controls that have previously been effective may be rendered obsolete with advances in computing power or improvements in algorithmic design. For instance, codes that were unbreakable 30 years ago may now be cracked using automated, randomized-guessing (brute force) techniques running on a mobile phone. Similarly, analysis of traffic patterns can help determine the best placement of network appliances and sensors or identify ways for an adversary to bypass these devices when used with malicious intent.

Machine learning greatly simplifies the programming of certain types of monitoring devices simply by analyzing patterns within common-use network traffic; however, the risk practitioner should keep in mind that if malicious traffic is already present in an environment during these initial phases of deployment, automated systems may learn to recognize it as part of the baseline.

It is important for the risk practitioner to maintain awareness of what new threats and attack vectors are gaining credibility in academic circles or visibility within real-world business environments. It is no longer feasible to rely on organizational obscurity or lack of clear adversaries as protection against malicious activity. Malicious actors often use arbitrary environments similar to their target networks and systems to train and hone their skills.

Sudden and potentially severe changes are also plausible, such as the global pandemic of 2020 and the shift of large portions of the workforce to remote environments. Controls need to be designed and implemented in ways that are suited to addressing the threats, vulnerabilities, and impacts of this dynamic environment. As conditions change, previous assumptions should be subject to regular re-examination by the risk practitioner, with the goal of identifying technical and procedural deficiencies before these can be exploited by waiting adversaries.

3.13.3 Artificial Intelligence and Emerging Risk

The use of AI has created numerous opportunities and risk for enterprises. As mentioned above, AI can be useful for automating and data aggregation tasks, enabling more effective identification and monitoring of risk. It is also useful in threat detection and prediction. Wide potential and relatively low cost of adoption makes it likely that AI will soon be present in most organizations. As that happens, the risk practitioner will need to ensure that AI systems are supported by suitable controls.

Traditional IT controls are effective for most AI solutions. However, the large amounts of data used in the development, training, and validation of AI and ML models require extensive oversight. It is also necessary to ensure that data protections extend to data aggregated for use for AI solutions. AI requires large volumes of data to build capabilities, and there is cause for concern that not all data ingested by AI models has historically been provided with the informed consent of its owners. Decision-making tools that leverage AI may also incorporate biases present in their training data. At the highest level, organizations using AI may wonder about the long-term risk associated with the enormous amount of electricity needed to provide these services and the associated environmental impact or the potential for sufficiently capable AI systems to lead to large-scale job loss and political instability.

One area of particular concern related to AI is the use of deepfake technology to create multichannel messaging for social engineering purposes. As discussed earlier in this chapter, administrative controls are frequently chosen because they rely on a human in the loop to exercise judgment. This flexibility can offer competitive advantage, but it can also be exploited by someone able to make a sufficiently convincing false claim. Real-world examples of high-profile deceptions often include deepfakes created by third parties from available voice samples and video that participants in video-conferencing calls could not distinguish from real participants. Believing that they were interacting with high-level executives, the staff members dutifully carried out actions they were told to complete, including wire transfers for substantial sums of money.

GenAI is another source of concern for IT risk practitioners. As with deepfake voice and video, GenAI can be trained to mimic a particular person, except its responses are typically provided in text. The number of people worldwide inclined to make or answer phone calls has been dropping steadily for years in the face of automated robocalls and deceptive practices, and this trend accelerated during the global pandemic of 2020. Today, communication by text message or a social-messaging app is much more common than email for many contexts, and all three written forms are considerably more popular than a phone call. In environments where text communication is the norm, GenAI may be able to carry out a complete social engineering attack without the need for active human involvement. Risk practitioners can also readily anticipate a point in the future when these technologies will converge, allowing a GenAI conversation to seamlessly move between text and deepfake voice or video. With more interactions occurring remotely, such a convergence can be expected to greatly reduce the utility of administrative controls as they exist today.

Case Study

Finteque is a mid-sized financial technology company based in The Netherlands. It provides payment processing services for corporations across the European Union. Finteque recently migrated a few of its critical applications to a cloud environment to reduce infrastructure costs and increase scalability. To address regulatory and compliance concerns, the IT risk management team uses a comprehensive monitoring program, which includes automated vulnerability scanning, compliance monitoring, regular reviews of online threat intelligence sources, and regular system audits.

During a recent review, a member of the data privacy team notices unusual behavioral patterns in cloud access logs, which identify multiple failed authentication attempts from global IP addresses.

1. While the attempts were unsuccessful, which of the following **BEST** describes the risk emerging as a result of this issue? (Select all that apply.)

   A. Unauthorized access to client financial data

   B. Possible unpatched vulnerabilities on the cloud service provider's system

   C. Lack of proper service level agreements (SLAs) captured in the service contract

   D. Insufficient compensating controls on organizational data

2. The risk management team suggests the need to select and implement new controls to address this vulnerability. What are some considerations that should impact this decision?
3. Which of the following would **BEST** ensure the successful remediation of the identified cloud security risk? (Select all that apply.)

   A. Assigning ownership and responsibility for remediation actions

   B. Accepting the risk, as the cloud service provider is planning on patching the vulnerability

   C. Establishing a timeline for changes and tracking the status of the project

   D. Updating the parameters on the existing vulnerability scanning system

4. Which of the following metrics would **MOST** effectively monitor the effectiveness of the newly implemented controls?

   A. Number of successful cloud deployments per month

   B. Average time spent reviewing security logs

   C. Number of failed authentication attempts

   D. Number of cloud service interruptions

Chapter 3 Answer Key

Case Study

1. **A. This indicates a potential advanced persistent threat, which if left unaddressed could result in a successful breach and unauthorized access to client data.**

   B. It is most likely that attackers have discovered and are attempting to exploit an unpatched vulnerability in the cloud service provider's identity management services.

   C. While the contract may stipulate patching and security procedures, it is not clear if the cloud service provider had previously identified this issue. Likewise, a patch could be scheduled to be deployed, but attackers took advantage of the situation to attempt to breach the system.

D. The scenario does not indicate that existing compensating controls were lacking, as the attempts to breach the system were unsuccessful.

2. Possible answers include:
   - Compliance with legal and regulatory requirements (e.g., GDPR)
   - Privacy by design practices
   - Vendor controls and patch management
   - Potential vulnerabilities introduced by the new and updated controls
   - Stakeholder concerns
   - Business objectives

3. **A. Control ownership ensures that a person or team is assigned to a remediation task as well as the performance and monitoring of the change.**

   B. Accepting the risk is not an appropriate treatment option in this instance as a breach would expose personally identifiable information (PII), which would result in significant financial and reputational consequences.

   C. Timelines and a project plan help to establish accountability for the completion of remediation tasks and ensure the vulnerability is addressed.

   D. Updating the vulnerability scanning system does not address the remediation process.

4. A. The number of successful cloud deployments per month reviews operational performance, not the effectiveness of the control.

   B. The average time spent reviewing security logs is an operational metric, not a security metric.

   C. The number of failed authentication attempts provides the most insight into the effectiveness of the new control, as the initial vulnerability showed a significant increase. A decrease would indicate that updated controls have successfully addressed the risk.

   D. Availability, while important to monitor for vendor management, would not necessarily reflect the effectiveness of the updated controls.

[37] All Blue Team members are cybersecurity defenders, but not all defenders are part of the Blue Team. This designation is specific to *proactive* defense.